



网络安全技术及应用

(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编



机械工业出版社
CHINA MACHINE PRESS

第9章 操作系统安全

回顾

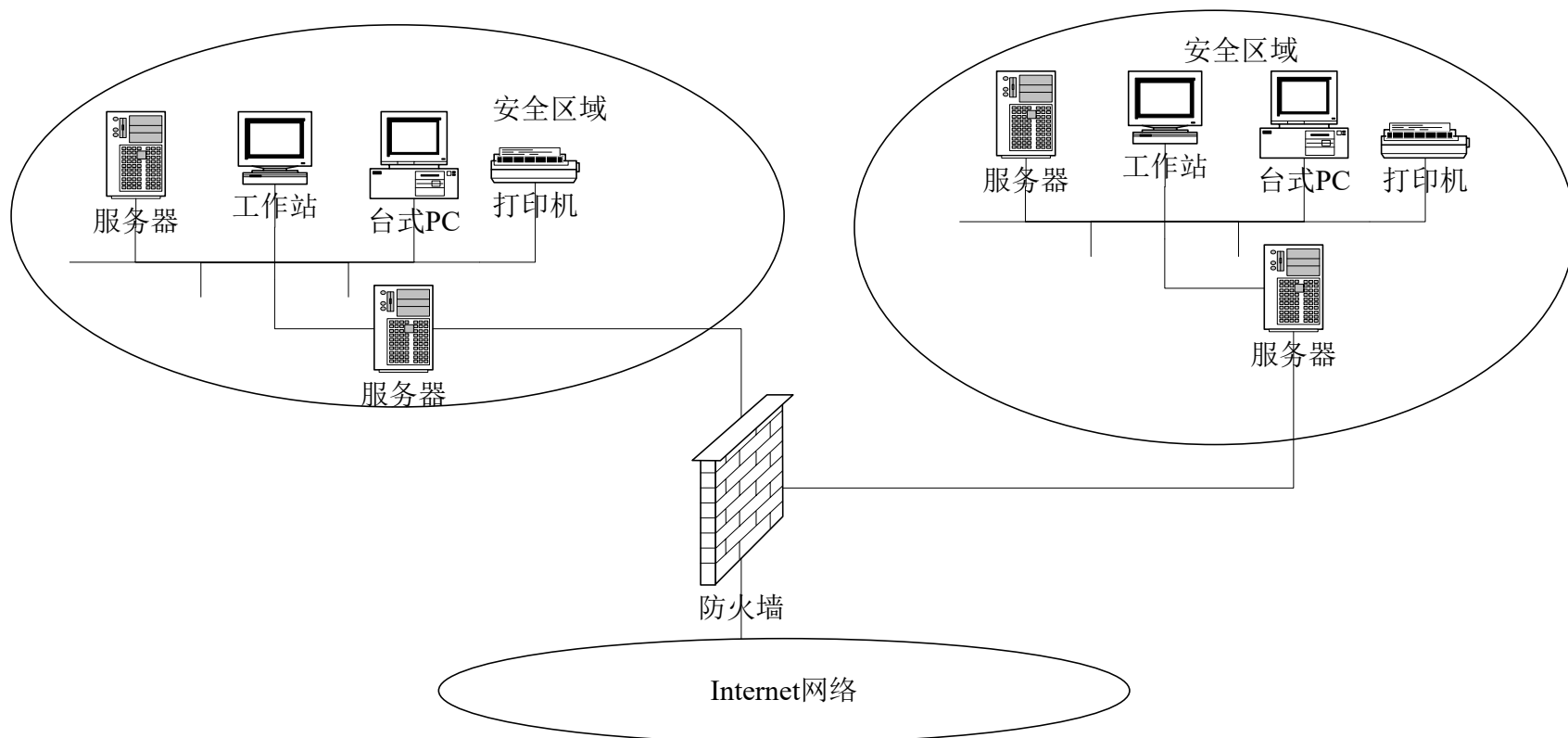


图8-1 网络防火墙的部署结构

回顾

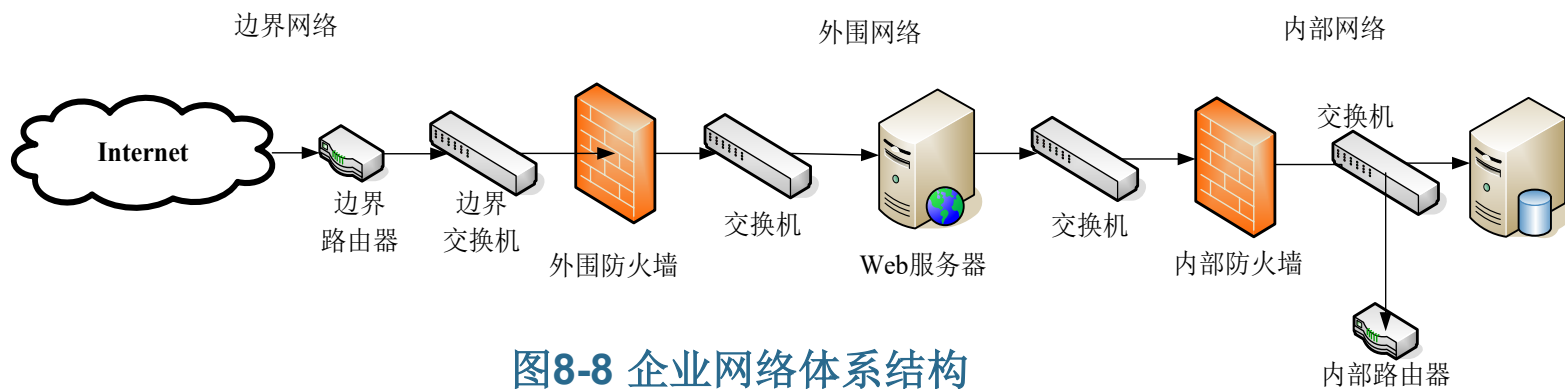


图8-8 企业网络体系结构

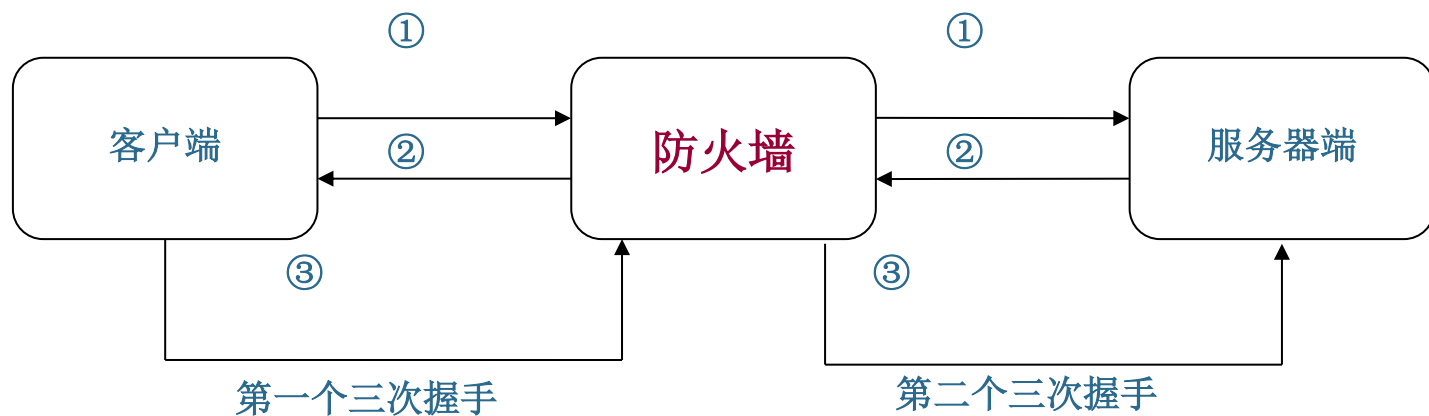


图8-16 两个三次握手过程

回顾

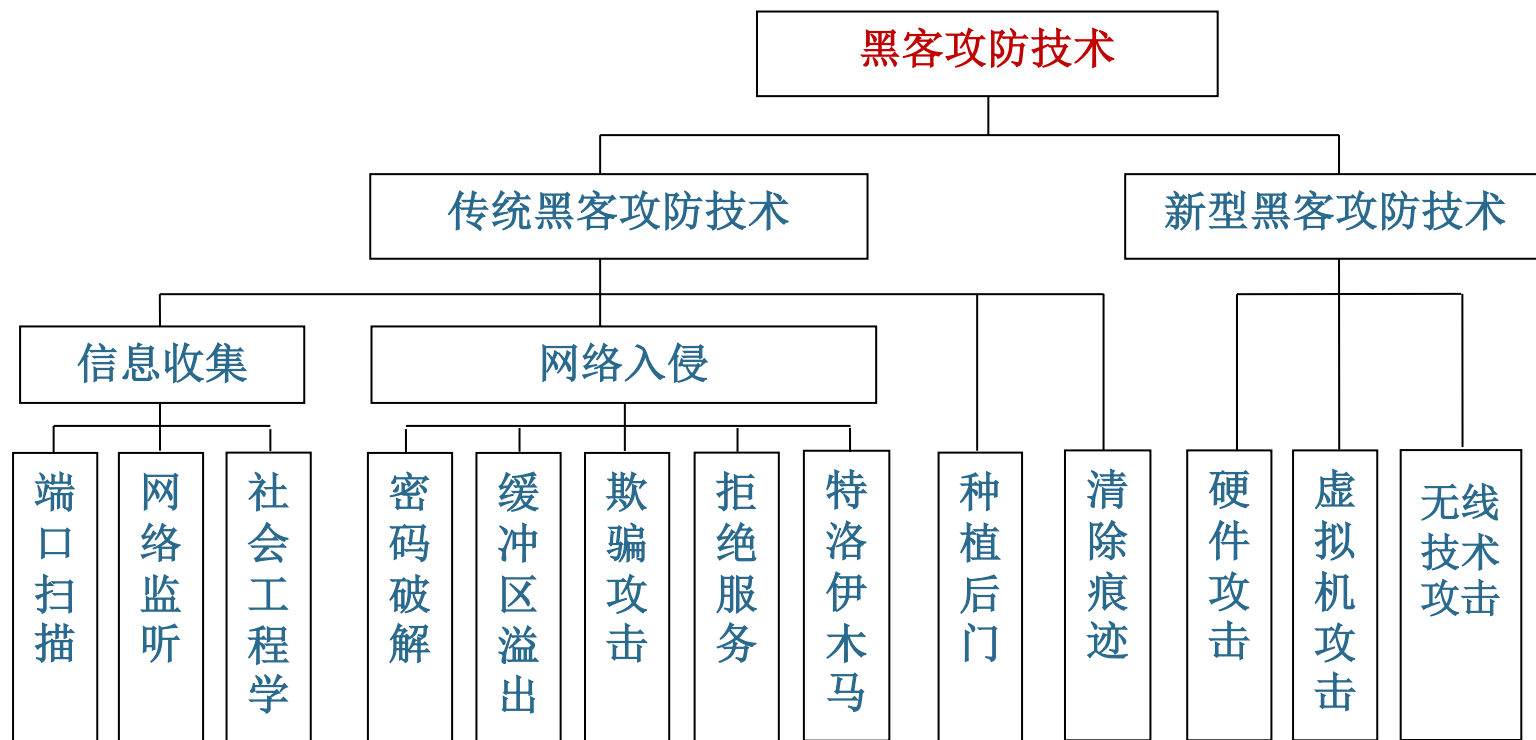
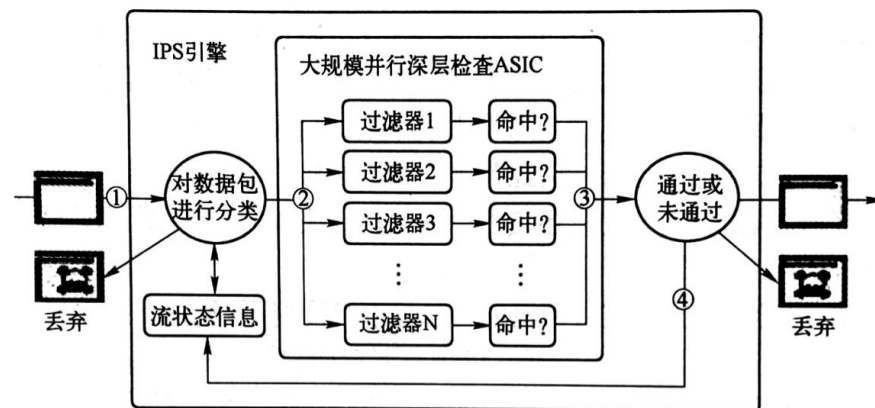
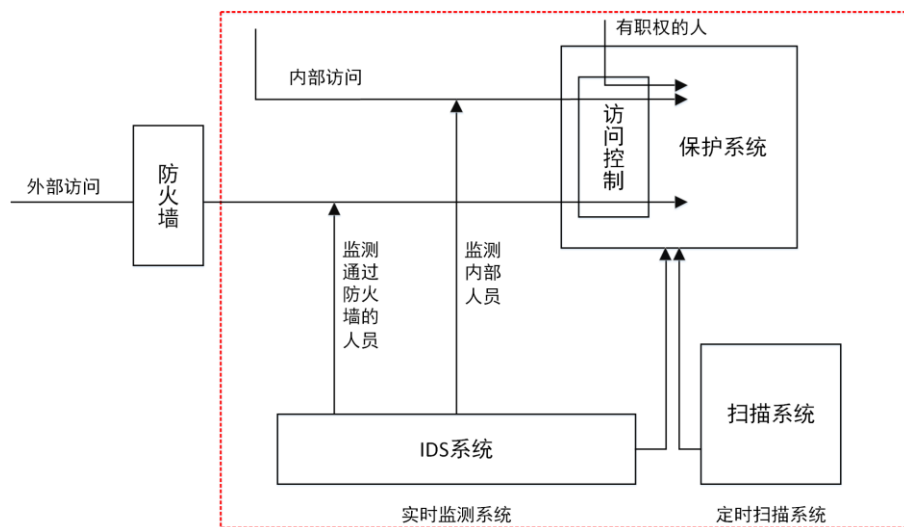


图4-2常用的黑客攻防技术

回顾



- ① 根据报头和流信息，每个数据包都会被分类。
- ② 根据数据包的分类，相关的过滤器将被用于检查数据包的流状态信息。
- ③ 所有相关过滤器都是并行使用的，如果任何数据包符合匹配要求，则该数据包将被标为命中。
- ④ 被标为命中的数据包将被丢弃，与之相关的流状态信息也会更新。指示系统丢弃该流中删除的所有内容。

入侵检测与防御系统

回顾

实用密码技术主要包括2种：

- **对称密码体制**

- 古典对称密码
- 现代分组密码
- 现代流密码算法
- 现代散列算法

- **非对称密码体制**

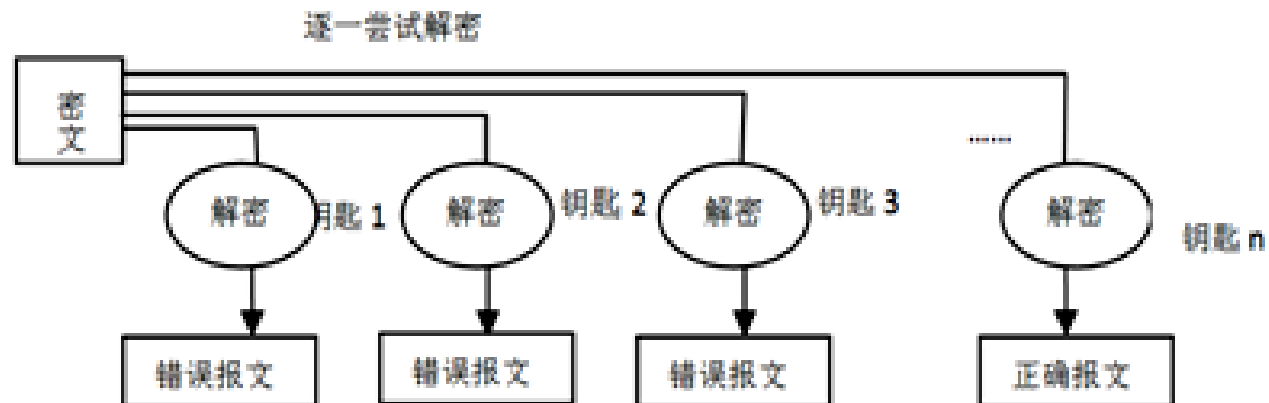
- **数字签名**（综合应用**散列算法**和**非对称密码体制**）

回顾

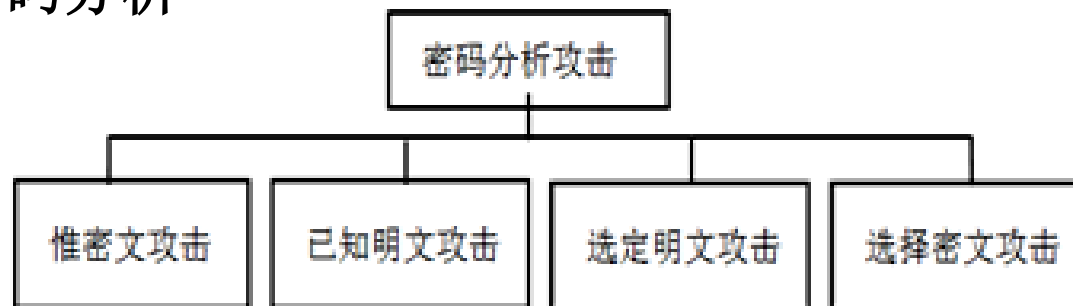
■ 密码破译方法

■ 穷举搜索密钥攻击

■ 例如，DES加密的密钥为56位。



■ 密码分析

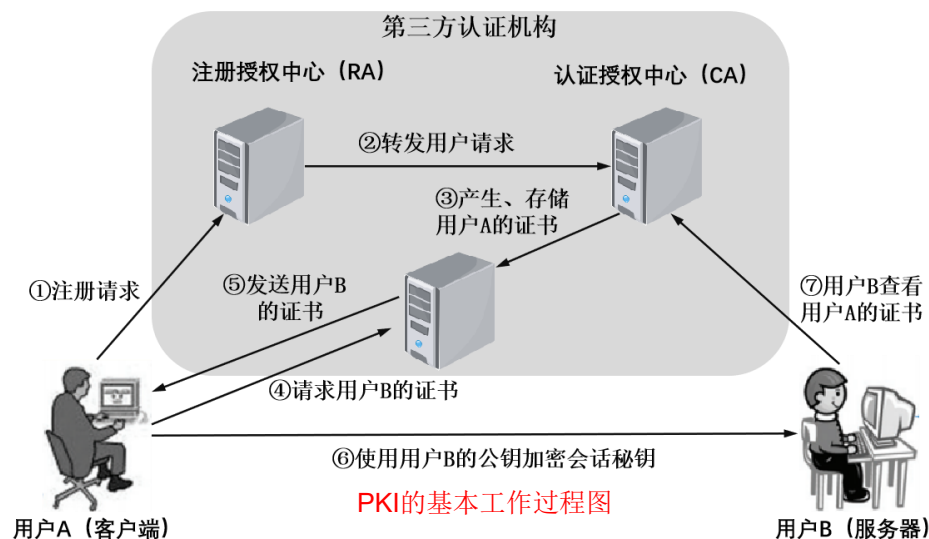
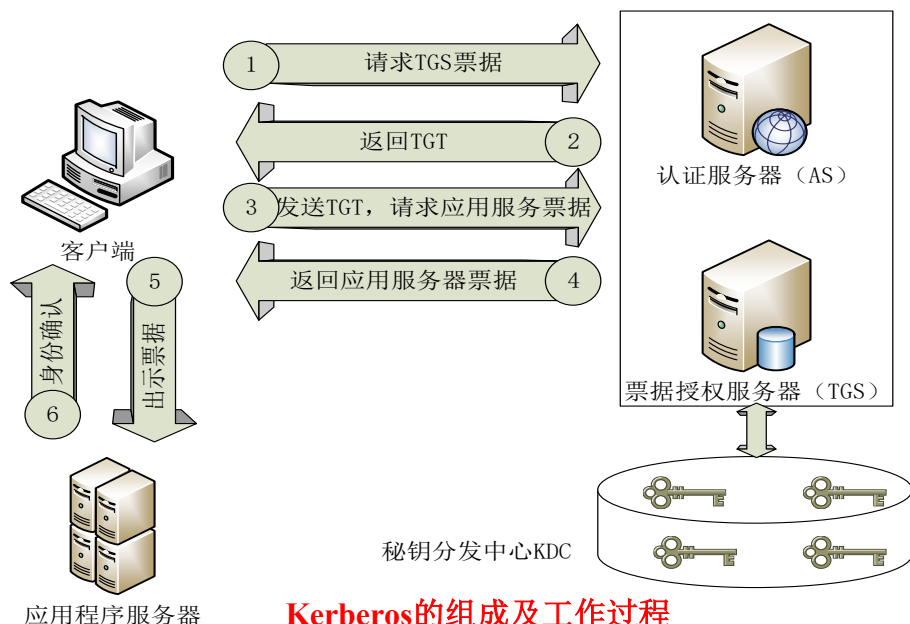


回顾

通常，身份认证基本方法有三种：

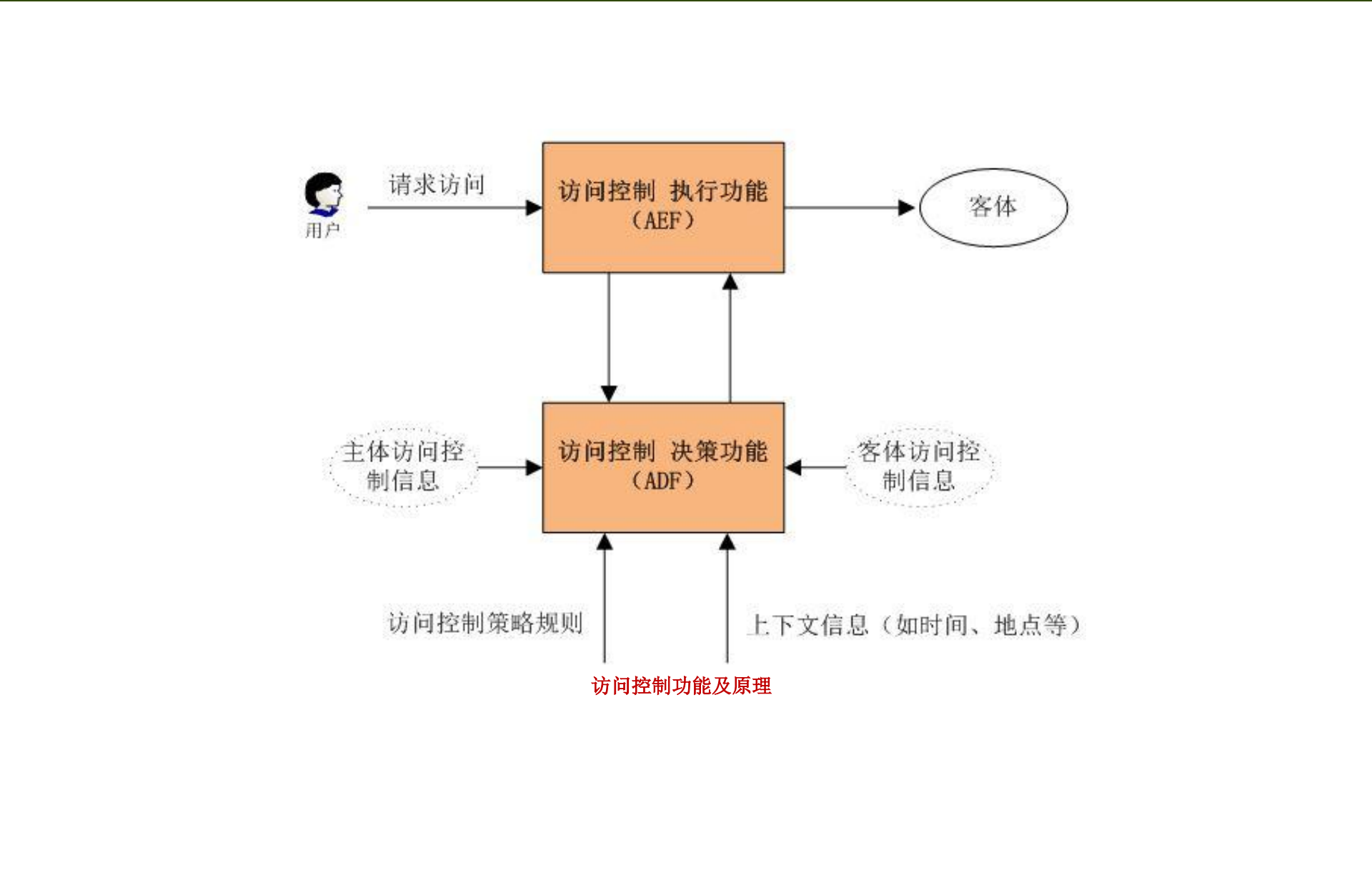
你知道什么？你有什么？你是谁？

- 1) 用户所知道的事物，如口令、密码等。
- 2) 用户拥有的物品，如身份证、智能卡(如信用卡)、**USB Key**
- 3) 用户所具有的生物特征，如指纹、虹膜、视网膜、声纹、笔迹、**DNA**、人脸信息等。

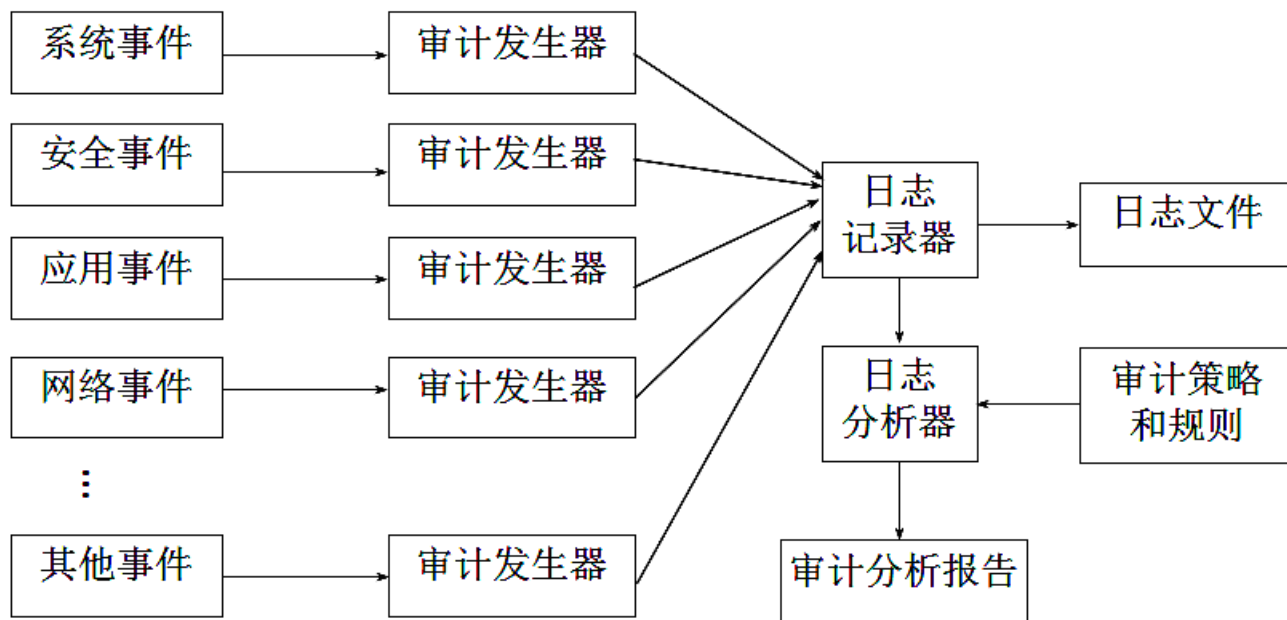




回顾



回顾



审计系统的基本结构

回顾

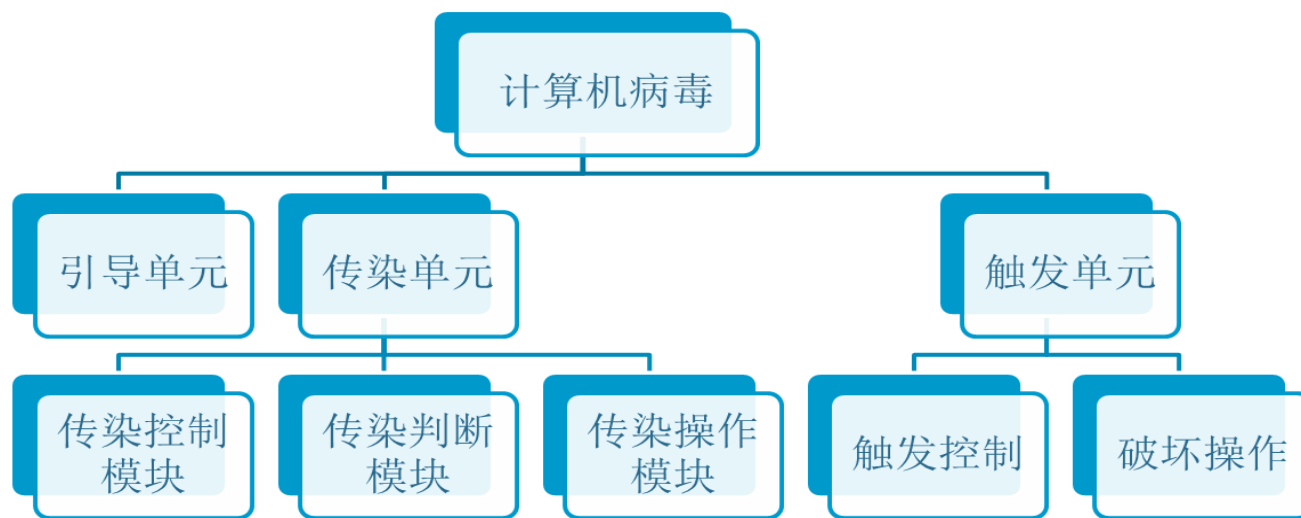


图7-1 计算机病毒的主要构成

回顾

■ 计算机病毒的检测

特征代码法：采集已知病毒样本，打开被检测文件，在文件搜索中检查文件是否含有病毒数据库中的病毒特征代码；因为特征代码与病毒一一对应，如果发现病毒特征代码，便可以断定被查文件中患有何种病毒。

行为检测法：利用病毒的特有行为特征对病毒进行监测的方法称为行为监测法。

校验和法：计算正常文件内容的校验和，将该校验和写入文件或写入其他文件中保存。在文件使用过程中，定期或每次使用文件前，检查文件现在内容并算出校验和，用算出的校验和与原来保存的校验和对比是否一致，因而可以发现文件是否感染，这种方法叫校验和法。

启发式扫描法

软件模拟法



回顾

■ 常见病毒的清除方法

将感染病毒的文件的病毒代码摘除，使之恢复成可以正常运行的健康文件，称为**病毒的清除**，有时称为**对象恢复**。

对一般常见的病毒，通常利用杀毒软件即可清除。



若单个可执行文件的病毒不能被清除，可将其删除重新安装。



若多数系统文件和应用程序被破坏，且中毒较重，删除后重新安装。



当感染的是关键数据文件，或受破坏较重，可请专业人员进行清除和数据恢复。

杀毒后重启，再用查杀病毒软件检查系统，并确认完全恢复正常。

回顾

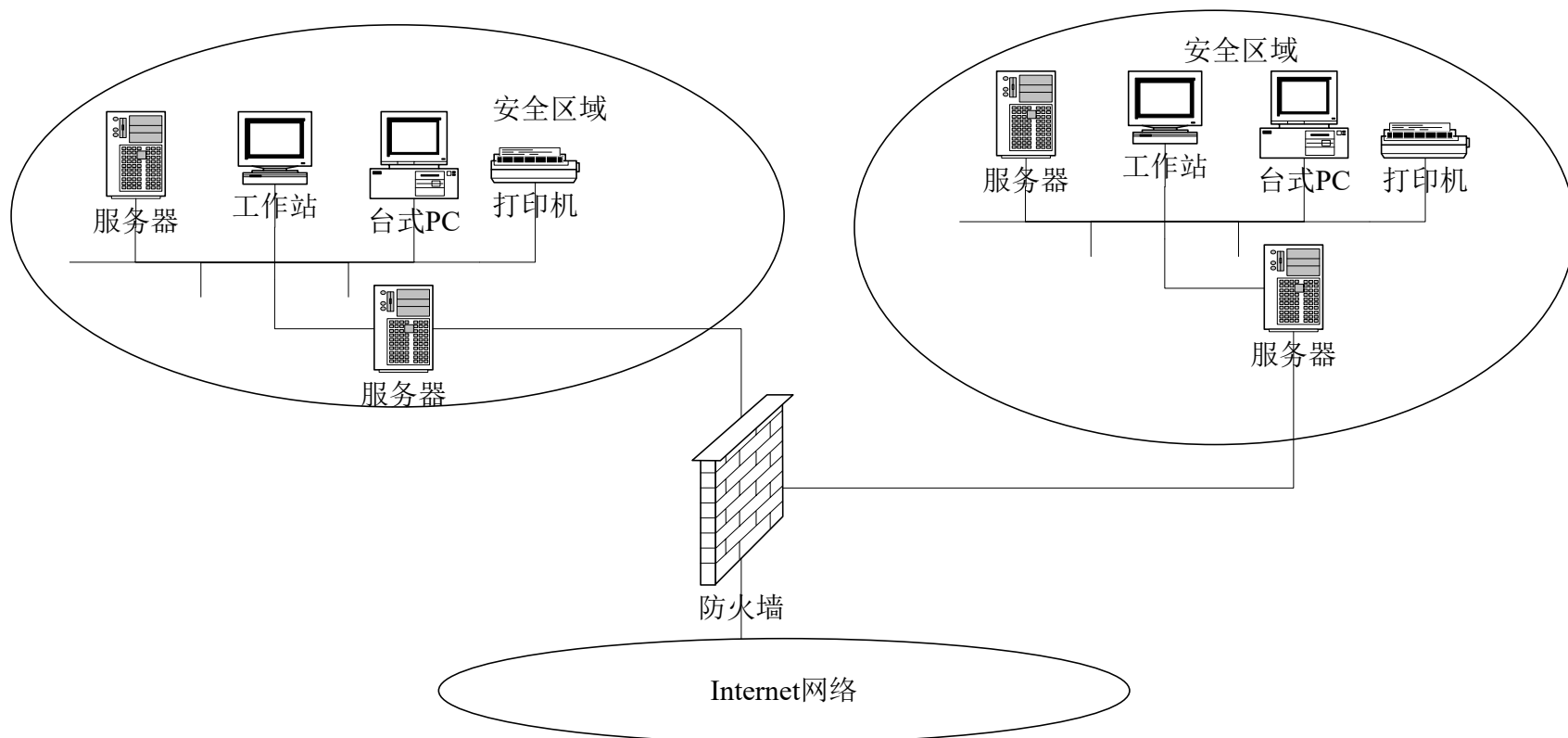


图8-1 网络防火墙的部署结构

目 录

9.1 操作系统安全概述

9.2 Windows操作系统的安全性及配置

9.3 UNIX操作系统的安全性及配置

9.4 Linux操作系统的安全性及配置

9.5 操作系统的安全加固和恢复

9.6 本章小结

9.7 实验9 Windows Server 2022安全配置实验



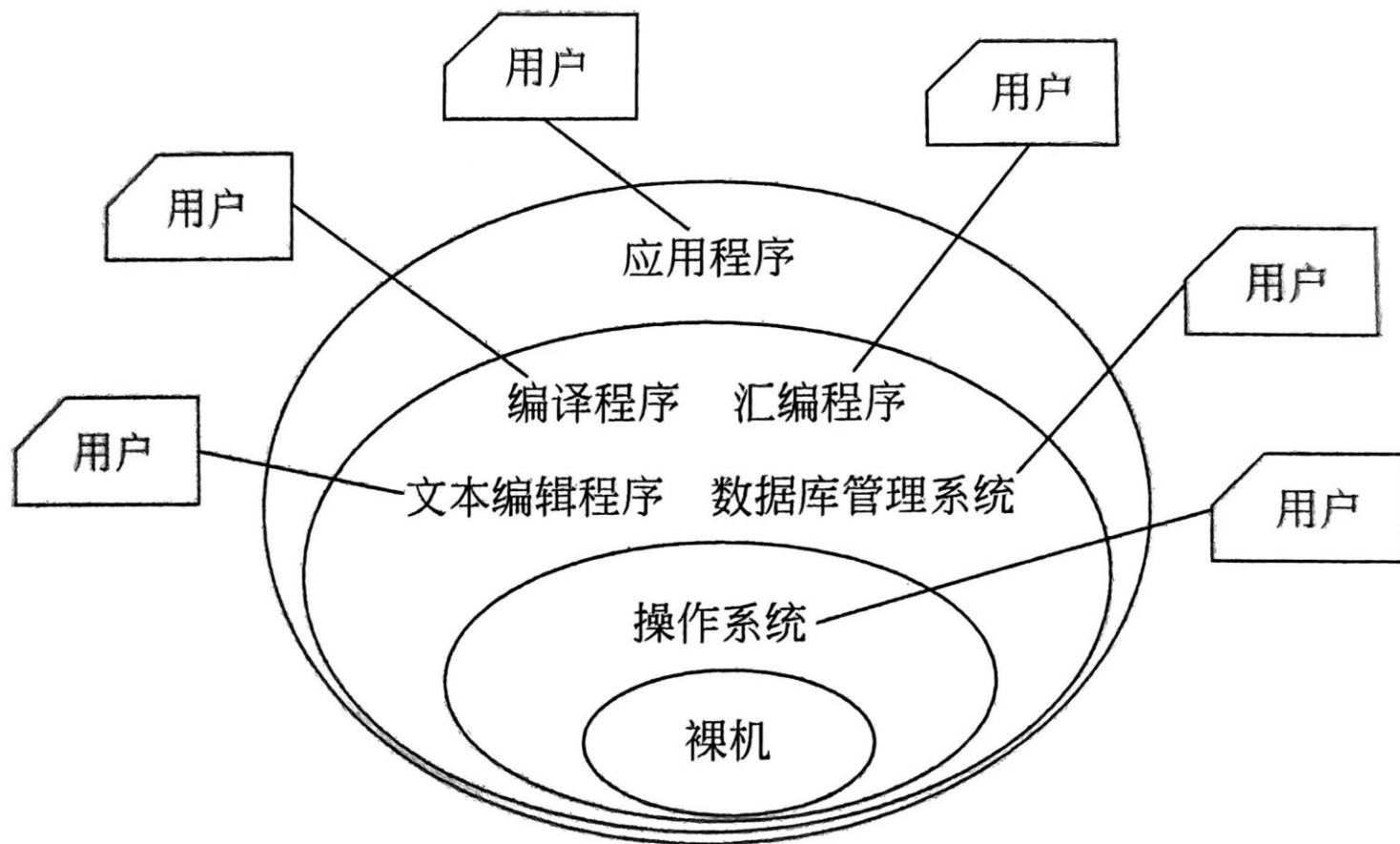
教学目标

教学目标

- 理解操作系统安全的相关概念和内容 **重点**
- 掌握常用操作系统的主要安全机制 **重点**
- 掌握Windows、UNIX和Linux安全策略
- 学会系统加固和系统恢复的常用方法



9.1 操作系统安全概述



计算机系统的组成

9.1 操作系统安全概述

操作系统5大功能：处理器管理、存储器管理、设备管理、文件管理和作业管理

9.1.1 操作系统安全概念

引导案例

操作系统被视为信息产业的“魂”。近年来，从Win7停服到勒索病毒，从CentOS停服到震惊业界的Log4j2漏洞，操作系统和软件行业的安全事件频发，凸显出拥有自主操作系统的重要性。我国在操作系统领域的探索已长达三十余年，市面上能查询到的“国产操作系统”（麒麟、统信、deepin、鸿蒙等）至少有15种，被称为操作系统“国家队”的麒麟软件，被评为“2020年度央企十大国之重器”。

操作系统是计算机系统最基础的软件，在信息系统的安全中，操作系统的安全性具有**至关重要的基础作用**。

- 1) 直接为用户数据及处理提供各种安全**保护机制**。
- 2) 为应用程序提供可靠的**运行环境**，保证其各种安全机制正常发挥作用。
- **常用的操作系统**有Windows类、NetWare类、UNIX系统和Linux等，其安全性对整个网络系统都很重要。

9.1 操作系统安全概述

央视新闻

央视新闻

4-15 10:51 来自 微博网页版 已编辑

【#美国向黑龙江Windows发加密字节#】#美国网络攻击哈尔滨亚冬会细节# #悬赏通缉3名美国特工# 技术团队还发现，亚冬会期间美国国家安全局（NSA）向黑龙江省内多个基于微软Windows操作系统的特定设备发送未知加密字节，疑为唤醒、激活微软Windows操作系统提前预留的特定后门。（总台央视记者李文杰 张岗 李可婧） 收起

最新消息

央视新闻

央视新闻



关于对3名美国网攻窃密人员的 悬赏通告

2025年哈尔滨第九届亚冬会期间，赛事信息系统及黑龙江省内关键信息基础设施遭境外网络攻击。经查，美国国家安全局特定入侵行动办公室（Office of Tailored Access Operation，简称“TAO”）凯瑟琳·威尔逊（Katheryn A. Wilson）、罗伯特·思内尔（Robert J. Snelling）、斯蒂芬·约翰逊（Stephen W. Johnson）等3名特工，参与实施了上述网络攻击活动。同时，调查显示该3名特工曾多次对我国关键信息基础设施实施网络攻击，并参与对华为公司等企业的网络攻击活动。

为依法严厉打击境外势力对我网攻窃密犯罪，切实维护国家网络空间安全和人民生命财产安全，哈尔滨市公安局决定对上述3名犯罪嫌疑人进行悬赏通缉。发现有关人员线索可立即向公安机关举报，公安机关将对举报人身份信息严格保密。凡向公安机关提供有效线索的举报人，以及配合公安机关抓获有关犯罪嫌疑人的有功人员，公安机关将给予一定金额的奖励。



举报电话：0451-110

9.1 操作系统安全概述

■ 9.1.1 操作系统安全概念

■ 操作系统安全是指满足安全策略要求，具有相应的安全机制及安全功能，符合特定的安全标准，在一定约束条件下，能够抵御常见的网络安全威胁，保障自身的安全运行及资源安全。

■ 国家标准《信息安全技术操作系统安全技术要求》(GB/T 20272-2019)根据安全功能和安全保障要求，将操作系统分成5个安全等级：用户自主保护级、系统审计保护级、安全标记保护级、结构化保护级、访问验证保护级。美国国防部根据《可信计算机系统安全评价准则》(TCSEC)，将操作系统的安全性分为4类7个安全级别。

9.1 操作系统安全概述

9.1.2 操作系统的主要安全问题

案例9-1 2022年8月，国家信息安全漏洞库（CNNVD）收到关于 Apple macOS Monterey安全漏洞（CNNVD-202208-3348、CVE-2022-32894）和Apple macOS Monterey安全漏洞（CNNVD-202208-3345、CVE-2022-32893）情况的报送。成功利用漏洞的攻击者可提升本地权限，并执行任意代码。iOS 15.6.1以下版本、iPadOS 15.6.1以下版本、macOS Monterey 12.5.1以下版本受上述漏洞影响。苹果官方随即发布了版本更新修复了该漏洞，建议用户及时尽快采取修补措施。

根据国家信息安全漏洞库（CNNVD）统计，2022年8月主流操作系统的漏洞统计情况如右表所示，其中Windows系列操作系统漏洞数量共63个，Android漏洞数量最多，共131个。

序号	操作系统名称	漏洞数量
1	Android	131
2	Windows 10	60
3	Windows Server 2022	57
4	Windows Server 2019	56
5	Windows 11	54
6	Windows Server 2016	53
7	Windows Server 2012	39
8	Windows Server 2012 R2	39
9	Windows 8.1	39
10	Windows Rt 8.1	37
11	Windows Server 2008	29
12	Windows Server 2008 R2	29
13	Windows 7	29
14	Linux Kernel	17

9.1 操作系统安全概述

■ 9.1.2 操作系统的主要安全问题

随着操作系统功能和性能的提升,导致代码规模日益庞大,难免在开发过程中产生安全漏洞,给操作系统带来安全威胁。目前,操作系统的主要安全问题包括以下5个方面。

(1) 操作系统是应用和服务运行的公共平台,操作系统安全漏洞是网络安全的主要隐患和风险。

(2) 通过操作系统漏洞或端口,获得授权或篡改未授权或越权数据信息,危害信息系统的保密性和完整性。

(3) 利用操作系统,破坏或影响计算机系统的正常运行或用户的正常使用,危害计算机系统的可用性。

(4) 以操作系统为对象,破坏或影响系统完成的功能,除了电脑病毒破坏系统正常运行和用户正常使用外,还有一些人为因素或自然因素,如干扰、设备故障和误操作也会影响软件的正常运行。

(5) 以软件为对象,非法复制或非法使用。通常网络入侵者通过相应的扫描工具,找出被攻击目标的系统漏洞,并策划相关的手段利用该漏洞进行攻击。

9.1 操作系统安全概述

■ 9.1.2 操作系统的主要安全问题

近年来，黑客对网络系统的攻击愈演愈烈，其手段也更为**复杂多样**，从最初的猜测用户密码、利用系统缺陷侵入，发展到现在的通过操作系统源代码，**分析操作系统漏洞**进行攻击。与此同时，网络的普及也使得**攻击工具和代码更容易被获取**，给操作系统的安全带来了极大威胁。

随着移动互联网和5G技术的发展，移动终端已成为人们生活和工作不可或缺的工具。然而，这些便利性的背后也带来了安全风险。**移动终端操作系统**安全问题不仅影响个人隐私，还可能对企业数据和关键信息造成威胁。

移动终端操作系统面临诸多安全问题，包括系统内核和组件的漏洞，易被攻击者利用获取权限、窃取信息或导致崩溃；恶意软件如木马、病毒等伪装成正常程序，窃取敏感信息、破坏系统或恶意扣费；应用程序过度获取权限、后台收集共享数据，以及备份恢复过程中的隐私泄露风险；弱密码、身份冒用和授权机制不完善等身份认证与授权问题；中间人攻击、不安全Wi-Fi和移动网络攻击等网络安全威胁；以及设备丢失被盗和硬件攻击带来的物理安全风险。

9.1 操作系统安全概述

9.1.3 操作系统安全机制

操作系统的安全问题直接危及整个网络信息系统的安全，因此，操作系统的安全目标是能够防范网络安全威胁，保障操作系统的安全运行及计算机系统资源的安全性，主要包括以下几个方面。

(1) 进入系统的用户具有唯一标识，并能进行身份真实性鉴别。（管好“人”）

```
C:\Users\user>whoami /user
```

用户信息

用户名	SID
desktop-g6gbiq1\user	S-1-5-21-107187497-26436345-2175096382-1001

CSDN @jqtt123

```
PS C:\Users\user> Get-WmiObject win32_useraccount | Select Name, SID
```

Name	SID
Administrator	S-1-5-21-107187497-26436345-2175096382-500
DefaultAccount	S-1-5-21-107187497-26436345-2175096382-503
Guest	S-1-5-21-107187497-26436345-2175096382-501
user	S-1-5-21-107187497-26436345-2175096382-1001
WDAGUtilityAccount	S-1-5-21-107187497-26436345-2175096382-504

CSDN @jqtt123

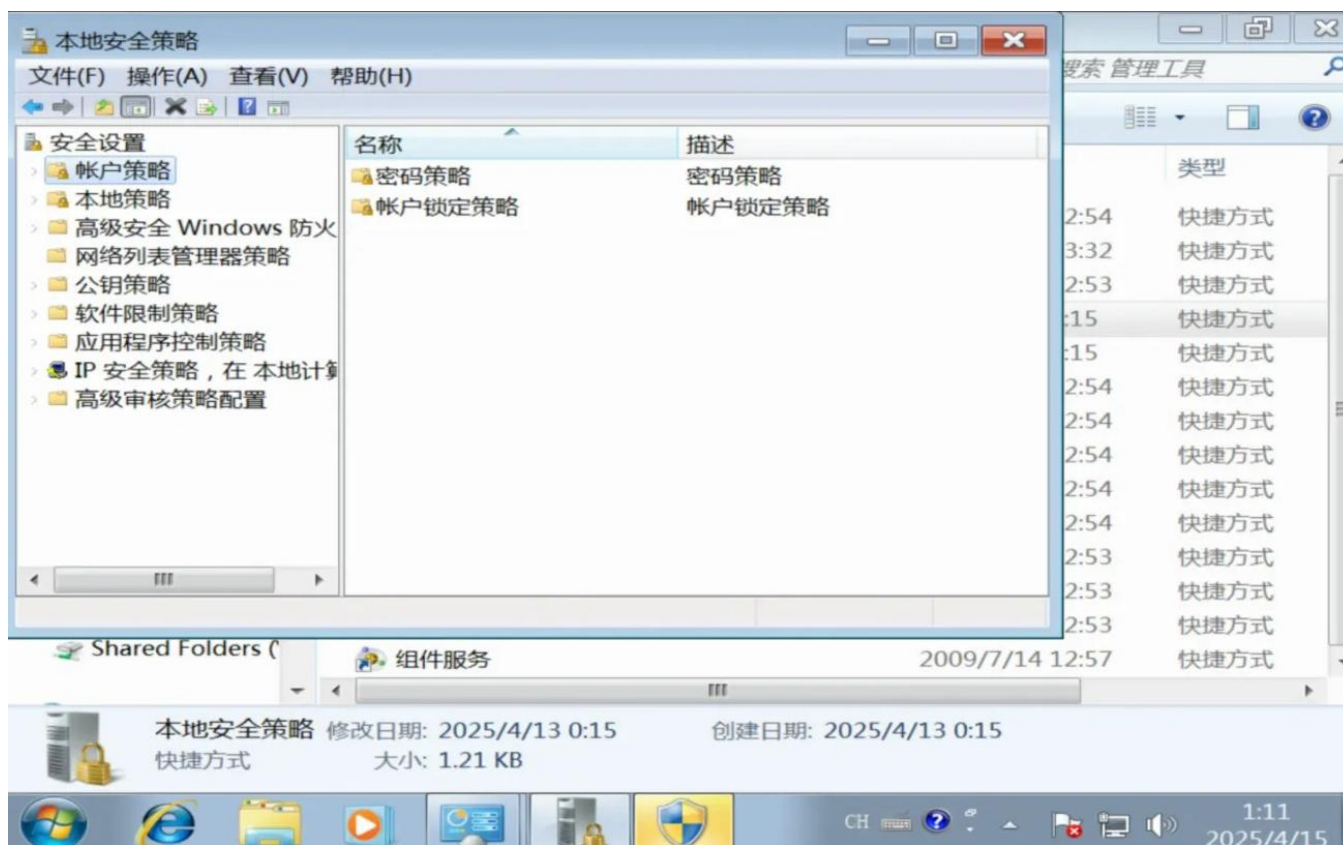
```
(base) jingkun@anonymous ~ % id jingkun
uid=501(jingkun) gid=20(staff) groups=20(staff),12(everyone),61(localaccounts),7
9(_appserverusr),80(admin),81(_appserveradm),98(_lpadmin),701(com.apple.sharepoi
nt.group.1),33(_appstore),100(_lpoperator),204(_developer),250(_analyticsusers),
395(com.apple.access_ftp),398(com.apple.access_screensharing),399(com.apple.acce
ss_ssh),400(com.apple.access_remote_ae)
```

```
zen@zen:~$ id zen
uid=1000(zen) gid=1000(zen) 组=1000(zen),4(adm),24(cdrom),27(sudo),30(dip),46(pl
ugdev),100(users),118(lpadmin)
zen@zen:~$ who zen
zen      seat0      2023-07-18 16:18 (login screen)
zen      tty2       2023-07-18 16:18 (tty2)
zen@zen:~$ whoami
zen
```

9.1 操作系统安全概述

■ 9.1.3 操作系统安全机制

(2) 按照系统**安全策略**对用户的操作进行**访问控制**，防止用户对计算机资源的非法访问。（管好“人”）

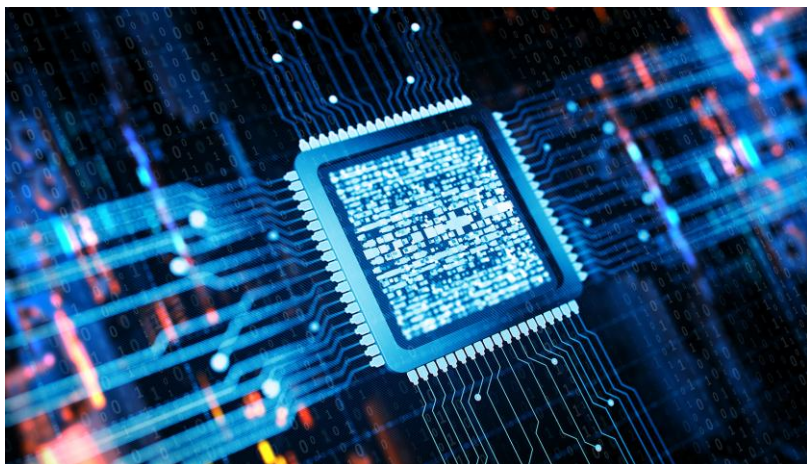


9.1 操作系统安全概述

■ 9.1.3 操作系统安全机制

操作系统的安全问题直接危及整个网络信息系统的安全，因此，操作系统的安全目标是能够防范网络安全威胁，保障操作系统的安全运行及计算机系统资源的安全性，主要包括以下几个方面。

- (1) 进入系统的用户具有唯一标识，并能进行身份真实性鉴别。（管好“人”）
- (2) 按照系统安全策略对用户的操作进行访问控制，防止用户对计算机资源的非法访问。（管好“人”）
- (3) 能够保护系统信息和数据的机密性、完整性和可用性。（看好“东西”）
- (4) 能够保护网络通信和网络服务的可用性。（看好“东西”）
- (5) 具有系统运行监督机制，防御恶意代码等攻击。（守住“系统”）
- (6) 具有自身安全保护机制及可信的恢复能力。（守住“系统”）



9.1 操作系统安全概述

■ 9.1.3 操作系统安全机制

操作系统的安全保障及安全目标的达成，需要具有一整套合理的安全机制。

- 1) **硬件安全**。是操作系统安全的基础保障机制，包括内存保护、I/O保护、运行保护及物理环境保护等。
- 2) **身份标识与鉴别**。即身份认证机制，对进入系统的用户进行身份唯一性标识，并在用户登录系统时进行身份真实性鉴别。
- 3) **访问控制**。指在身份认证的基础上，对操作系统的资源管理控制，防止资源滥用。
- 4) **最小特权管理**。为了维护操作系统的正常运行及安全策略的应用，传统的超级用户或进程通常具有超级权限的操作能力。例如，UNIX/ Linux等多用户操作系统的 root 用户具有所有特权，虽然便于系统维护和配置，但不利于系统的安全性。一旦特权用户的口令丢失、口令被冒充，或者其自身的误操作都可能会对系统造成极大的损失。最小特权管理就是操作系统不会分配给用户超过其执行任务所需的权限，以防止权限滥用，从而减少系统的安全风险。

9.1 操作系统安全概述

■ 9.1.3 操作系统安全机制

- 5) **可信路径**。可信路径就是确保终端用户能直接访问可信系统内核进行通信的机制。例如，操作系统对本地用户或远程用户进行初始登录或鉴别时，操作系统与用户之间建立的安全通信路径。可信路径能保护通信数据免遭修改、泄露，防止特洛伊木马模仿登录过程来窃取用户的口令。
- 6) **安全审计**。指操作系统对系统中有关安全的活动进行记录、检查及审核，主要目的是核实系统安全策略执行的合规性，以追踪违反安全策略的用户及活动主体，确认系统安全。
- 7) **系统安全加固**。也叫做系统安全增强，是通过优化操作系统的配置或增加安全组件，以提升操作系统的抗攻击能力。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

【案例 9-2】 2022 年 8 月，微软官方发布公告更新了 Microsoft Windows Point-to-Point Tunneling Protocol (CNNVD-202208-2560、CVE-2022-30133) 等多个安全漏洞，微软多个产品和系统受漏洞影响。成功利用上述漏洞的攻击者可以在目标系统上执行任意代码、获取用户数据、提升权限等。微软官方随即发布了漏洞修复补丁，建议用户及时确认是否受到漏洞影响，尽快采取修补措施。

■ 1. Windows系统安全

微软公司于 2021 年 11 月发布了 Windows Server 2022，在关键主题上引入了许多创新，如安全性、Azure 混合集成和管理以及应用程序平台，其中引入了许多提升系统安全性的功能，IT 和 SecOps 团队可以利用 Secured-core server 高级保护功能和预防性防御功能，跨硬件、跨固件、跨虚拟化层，加强系统安全性。新版本增加了较为快速、安全性较高的加密超文本传输协议安全(HTTPS)和行业标准 AES-256 加密，支持服务器消息块(SMB)协议。根据实际情况对系统进行全面安全的配置，以提高服务器的安全性。**Windows系统的安全**主要包括6个方面：

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 1) 文件系统

Windows Server 文件系统类型主要包括 FAT32 和扩展文件分配表 exFAT、NT 文件系统NTFS 和复原文件系统 ReFS，其中一直广泛应用的是 NTFS。FAT32 不提供文件系统级别的安全性。NTFS 是建立在保护文件和目录数据基础上的，可提供安全存取控制及容错能力，同时节省存储资源、减少磁盘占用量。NTFS文件系统所具备3个功能：错误预警功能、磁盘自我修复功能和日志功能。ReFS是Microson 在Windows Server 2012 中引入的，旨在增强 NTFS 的功能。如名称所示，ReFS 的一个主要优点就是通过更准确的检测机制和联机修正完整性问题的功能来增强对数据损坏的复原能力。但ReFS 并不提供与 NTFS 完全相同的功能，例如，ReFS不支持文件级压缩和加密，也不适用于引导卷和可移动媒体。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 1) 文件系统

NTFS 权限不但支持通过**网络访问的用户**对访问系统中文件的访问控制，也支持在**同台主机上以不同的用户**登录，对硬盘的同一个文件可以有不同的访问权限。当一个用户试图访问文件或者文件夹时，NTFS系统会检查用户使用的账户或者账户所属的组是否在此文件或文件夹的**访问控制列表(ACL)**中，如果存在，则进一步检查访问控制项(ACE)，根据控制项中的权限来判断其所具有的权限，如果访问控制表中没有账户或所属的组，那么拒绝该用户访问。NTFS 格式磁盘的文件加密采用**加密文件系统(Encrypting File System, EFS)**，为了防止文件数据所在的物理硬盘被非法窃取，弥补访问控制机制对数据保护能力的不足，EFS 允许用户以加密格式存储磁盘上的数据，将数据转换成不能被其他用户读取的格式。用户加密了文件之后，只要文件存储在磁盘上，它就会自动保持加密的状态。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 2) 域

域(Domain)是一组由网络连接而成的主机群组，是 Windows 中数据安全和集中管理的基本单位，域中各主机是一种不平等的关系，可将主机内的资源共享给域中的其他用户访问。域内所有主机和用户共享一个集中控制的活动目录数据库，目录数据库中包括了域内所有主机的用户账户等对象的安全信息，其目录数据库保存在域控制器中。当主机联入网络时，域控制器首先要鉴别用户使用的登录账号是否存在、密码是否正确。如果上述信息不正确，域控制器就拒绝登录，用户就不能访问服务器上有权限保护的资源，只能以对等网用户的方式访问 Windows 共享资源，从而在一定程度上保护了网络上的资源。单个网络中可以包含一个或多个域，并将多个域设置成活动目录树。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 3) 用户和用户组

在 Windows 用户账号中包含用户的名称与密码、用户所属的组、用户的权利和用户的权限等相关数据。当安装工作组或独立的服务器系统时，系统会默认创建一批内置的本地用户和本地用户组，存放在本地主机的 SAM 数据库中；而当安装成为域控制器时，系统则会创建一批域组账号。组是用户或主机账户的集合，可以将权限分配给一组用户而不是单个账户，从而简化系统和网络管理。当将权限分配给组时，组的所有成员都将继承那些权限。除用户账户外，还可以将其他组、联系人和主机添加到组中。将组添加到其他组，可创建合并组权限并减少需要分配权限的次数。

内置用户组是操作系统或应用程序中预定义的用户组，用于分配特定权限或资源访问权限。(如Windows的 Administrators)

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 3) 用户和用户组

用户账户通过**用户名和密码**进行标识，用户名为账户的文本标签，密码为账户的身份验证字符串。系统安装后会自动建立两个账号：一是系统管理员账户，对系统操作及安全规则有完全的控制权；二是提供来宾用户访问网络中资源的 Guest 账户，由于安全原因，通常建议 Guest 账户设置禁用状态。这两个账户均可改名，但都不能删除。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 4) 身份验证

身份验证是实现系统及网络合法访问的关键一步，主要用于对试图访问系统的用户进行身份验证。Windows Server 2019 将用户账号信息保存在 SAM 数据库中，用户登录时输入的账号和密码需要在 SAM 数据库中查找和匹配。通过设置可以提高密码的破解难度、提高密码的复杂性、增大密码的长度、提高更换频率等。Windows 10 的身份验证包括两方面：**交互式登录和网络身份验证**。

对用户进行身份验证时，根据要求不同，可使用多种行业标准类型的身份验证方法。

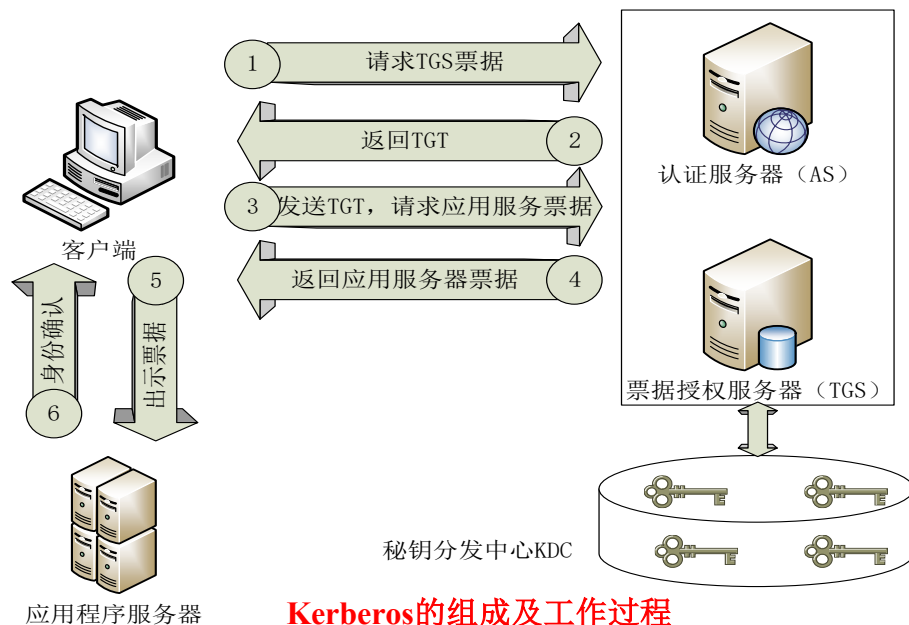
安全标识符SID用于唯一标识安全主体或安全组。

回顾

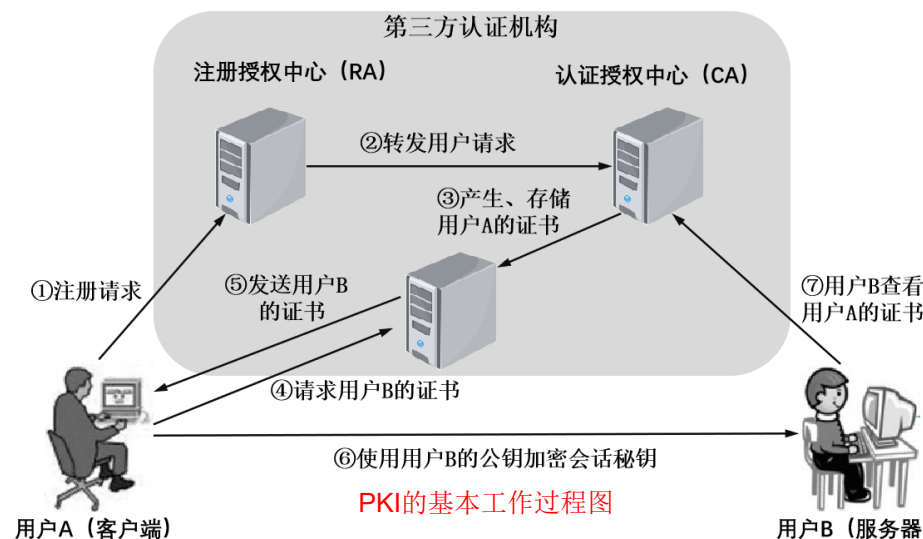
通常，身份认证基本方法有三种：

你知道什么？你有什么？你是谁？

- 1) 用户所知道的事物，如口令、密码等。
- 2) 用户拥有的物品,如身份证、智能卡(如信用卡)、**USB Key**
- 3) 用户所具有的生物特征，如指纹、虹膜、视网膜、声纹、笔迹、**DNA**、人脸信息等。



Kerberos的组成及工作过程



PKI的基本工作过程图

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 5) 访问控制

访问控制按 Windows 用户身份及其所归属的组来限制用户对某些信息项的访问，或限制对某些控制功能的使用。其通常**用于**系统管理员控制用户对服务器、目录、文件等网络资源的访问。

访问控制首先需要对用户身份的合法性进行验证，同时利用控制策略进行选用和管理工作。当用户身份和访问权限得到验证之后，还需要对越权操作进行监控，因此，访问控制的内容包括**认证、控制策略实现和安全审计**。

Windows操作系统主要采取：**自主访问控制、强制访问控制**。

9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

■ 6) 组策略

组策略 (Group Policy) 是管理员为用户和主机定义并控制程序、网络资源及操作系统行为的主要工具。通过使用组策略可以配置各种软件、主机和用户策略。**组策略对象** (Group Policy Object, GPO) 实际上是组策略配置的集合。组策略的配置结果保存在 GPO 中。组策略的**功能**主要包括：账户策略的设置、本地策略的设置、脚本的设置、用户工作环境的设置、软件的安装与删除、限制软件的运行、文件夹的重定向、限制访问可移动存储设备和其他系统设置。在 Windows Server 2019 系统中，系统用户和用户组策略管理功能仍然存在，并且包括几百种许可的组策略配置。这些组策略配置权限可以在域、用户组织单位站点或本地主机权限层级上申请，即在组策略配置方式上发生改变。

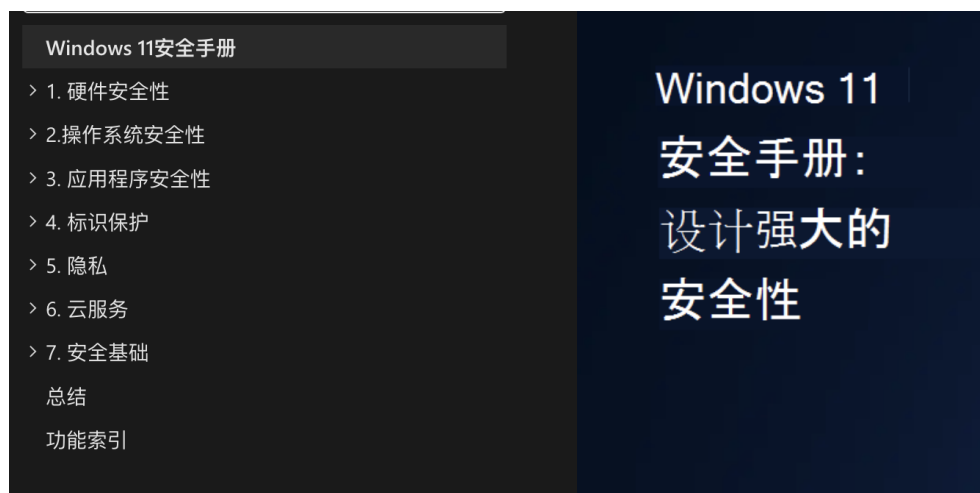
9.2 Windows操作系统的安全性及配置

■ 9.2.1 Windows系统的安全性

■ 1. Windows系统安全

Windows11安全手册:

<https://learn.microsoft.com/zh-cn/windows/security/book/>



9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

- 操作系统默认的安全配置不一定适合用户需要，可以根据实际情况对系统进行安全配置。常见的安全配置步骤如下。

- 1. 按用户需求最小化安装操作系统

Windows 系统功能较多，有些应用和服务的安全问题也不少，按照用户实际需求制定安全目标，并根据系统的业务应用，在操作系统安装或设置策略时进行合适的功能选择。最小化操作系统的目的是减少系统安全隐患的数目、降低系统安全风险。安装的一般要求包括：使用正版 Windows 操作系统、停止不需要的网络协议、使用 NTFS 分区、删除不必要的服务和组件等。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 2. 账户安全管理和安全策略

- 1) 更改默认的管理员账户名(Administrator)和描述，口令最好采用数字、大小写字母、特殊符号的组合，长度最好不少于 15 位。
- 2) 新建一个名为 Administrator 的陷阱账户，为其设置最小权限，然后设定采用组合且长度最好不低于 20 位的口令。
- 3) 将 Guest 账户禁用，并更改名称和描述，然后输入一个复杂的密码。
- 4) 在“运行”对话框中输入 gpedit.msc 命令(Windows 家庭版需要进一步设置)，在打开的“组策略编辑器”窗口中，按照树形结构依次选择“主机配置” - “windows 设置” - “安全设置” → “账户策略” → “账户锁定策略”，在右侧子窗口中对“账户锁定策略”的 3 种属性分别进行设置：“账户锁定阈值”设为“3 次无效登录”，“账户锁定时间”设为“30 分钟”，“复位账户锁定计数器”设为“30 分钟”。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 2. 账户安全管理及安全策略

- 5) 同样，在“组策略编辑器”窗口中，依次选择“主机配置”→“windows 设置”→“安全设置”→“本地策略”→“安全选项”，在右侧子窗口中将“**登录屏幕上不要显示上次登录的用户名**”设置为“启用”。
- 6) 在“组策略编辑器”窗口中，依次选择“主机配置”→“Windows 设置”→“安全设置”→“本地策略”及“用户权利分配”，在右侧子窗口中将“**从网络访问此主机**”下只保留“Internet 来宾账户”和“启动IIS 进程账户”。如果使用 ASPNET，则需要保留“Asp.net 账户”。
- 7) 创建一个 **User 账户**，运行系统，如果要运行特权命令，使用 **Runas** 命令。该命令允许用户以其他权限运行指定的工具和程序，而不是当前登录用户所提供的权限。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 3. 禁用所有网络资源共享

- 1) 单击“开始”按钮，选择“设置”选项(不同版本有所不同)，再依次选择“控制面板”→“管理工具”→“主机管理”→“**共享文件夹**”选项，然后把其中的**所有默认共享都禁用**。注意，IPC共享服务器每启动一次都会打开，需要重新停止。
- 2) **限制IPCS默认共享**，可通过修改注册表“HKEY LOCAL MACHINE \SYSTEM\CurrentControlSet \Services\ lanman server parameters”来实现，在右侧子窗口中新建一个名称为“restrictanonymous”、类型为REG DWORD 的键，将其值设为“1”。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 4. 关闭不需要的服务

右击“Windows 开始”，在弹出的快捷菜单中选择“计算机管理”命令，在“**计算机管理**”窗口中的左侧选择“服务和应用程序”——“**服务**”，在右侧窗口中将出现所有服务。右键选择不需要的服务，点击“禁用”。

- 1) Bluetooth Handsfree Service: 没有蓝牙的用户可以关闭。
- 2) Fax: 利用计算机或网络上的可用传真资源发送和接收传真。
- 3) Workstation: 创建和维护到远程服务的客户端网络连接。
- 4) Ssdp Discovery: 自动发现具有UPnP (Universal Plug and Play, 通用即插即用) 的设备。
- 5) Smart Card: 管理计算机对智能卡的读取访问基本上用不上。
- 6) Print Spooler: 将文件加载到内存中以便稍后打印，如果没装打印机，可以禁止该服务。
- 7) RemoteRegistry: 使远程用户能修改此计算机上的注册表设置。如果此服务被终止，只有此计算机上的用户才能修改注册表。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 5. 打开相应的审核策略

单击“开始”菜单，选择“运行”命令，输入“gpedit.msc”并按〈Enter〉键。在打开“组策略编辑器”窗口中，按照树形结构依次选择“主机配置”→“Windows 设置”→“安全设置”→“审核策略”选项。建议**审核项目的相关操作**如表 9-2所示。

审核项目	相关操作
审核策略更改	成功和失败
审核登陆事件	成功和失败
审核对象访问	失败
审核目录服务访问	失败
审核特权使用	失败
审核系统事件	成功和失败
审核账户登录事件	成功和失败

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 6. 管理网络服务

- (1) **禁用远程自动播放功能**。Windows 操作系统的自动播放功能很容易被攻击者利用来执行远程攻击程序，因此最好关闭该功能。在“运行”对话框中输入“gpedit.msc”并按〈Enter〉键，在打开的“组策略编辑器”窗口中依次选择“主机配置”→“管理模板”-“系统”选项，在右侧子窗口中找到“关闭自动播放”选项并双击，在弹出的对话框中选择“已启用”单选按钮，然后在**“关闭自动播放”下拉列表框中选择“所有驱动器”**，单击“确定”按钮即可生效。
- (2) **禁用部分资源共享**。在局域网中，Windows 系统提供了文件和打印共享功能，但在享受到该功能带来的便利的同时，也会向黑客暴露不少漏洞，从而给系统造成很大的安全风险。用户可以在网络连接的“属性”对话框中**禁用“网络文件和打印机共享”**。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 7. 清除页面交换文件

Windows操作系统中的页面交换文件中隐藏有不少重要隐私信息，并且这些信息全部是动态产生的，如果不及时清除，很可能会成为攻击者入侵的突破口。

在“开始”菜单中，选择“运行”命令，在打开的“运行”对话框中输入“**Regedit**”命令，打开**注册表**编辑窗口，在该窗口中依次展开

“HKEY_local_machine\system\currentcontrolset\control\sessionmanager\memory management”分支，在右侧子窗口中，将“Clear Page File At Shutdown”的键值设置为“1”。完成设置后，退出注册表编辑窗口，并重新启动主机系统使设置生效。

9.2 Windows操作系统的安全性及配置

■ 9.2.2 Windows 安全配置

■ 8. 文件和文件夹加密

在 NTFS 文件系统格式下，打开“Windows 资源管理器”，在任何需要加密的文件和文件夹上右击，在弹出的快捷菜单中选择“属性”命令，在弹出的对话框中单击“常规”选项卡下的“高级”按钮，选中“**加密内容以便保护数据**”复选框，然后单击“确定”按钮。

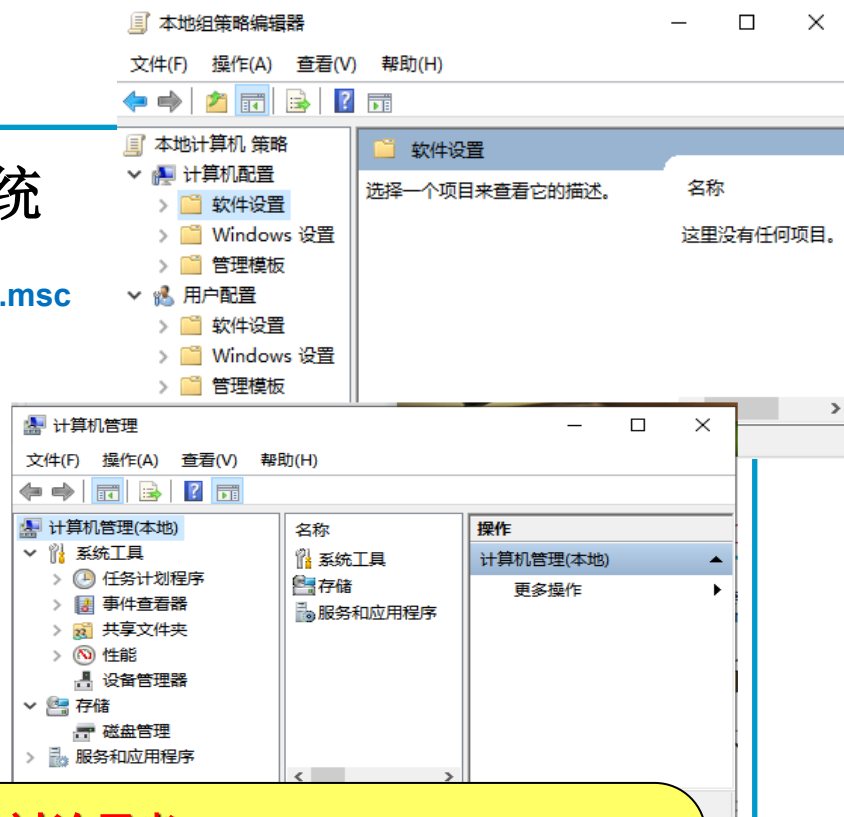
9.2 Windows操作系统的安全性及配置

9.2.2 Windows 安全配置

- 1. 按用户需求最小化安装操作系统
- 2. 账户管理和安全策略— 运行gpedit.msc
- 3. 禁用所有网络资源共享(管理工具)
- 4. 关闭不需要的服务(此电脑-管理) ➔
- 5. 打开相应的审核策略 运行gpedit.msc
- 6. 安全管理网络服务 运行gpedit.msc
- 7. 清除页面交换文件 运行Regedit
- 8. 文件和文件夹加密

资源管理器-属性-常规-高级-加密内容以保护数据

Windows Server服务器管理和安全性



讨论思考：

- 1) 分析系统应用，那些服务是需要的，那些服务是可以关闭的？
- 2) 分别说明系统身份验证各方法的应用。
- 3) NTFS文件系统格式和其他文件系统格式有什么区别？

9.3 UNIX操作系统的安全性及配置

■ 9.3.1 UNIX系统的安全性

■ Unix是一个强大的**多用户、多任务**操作系统，支持多种处理器架构，按照操作系统的分类，属于**分时操作系统**。

■ 最早由 Ken Thompson、Dennis Ritchie 和 Douglas McIlroy于1969年在AT&T的**贝尔实验室开发**。经过长期的发展和完善，Unix已成为一种**服务器主流的操作系统**和基于这种技术的产品大家族。由于Unix**具有技术成熟、可靠性高、网络和数据库功能强、伸缩性突出和开放性好等特色**，可满足各行各业的实际需要，特别能满足企业重要业务的需要，已经成为主要的工作站平台和重要的企业操作平台。但UNIX对源代码实行知识产权保护，因此多由一些大型公司在维护。

9.3 UNIX操作系统的安全性及配置

■ 9.3.1 UNIX系统的安全性

【案例9-4】 2022年2月，日本信息通信技术（ICT）企业巨头富士通（Fujitsu）在官网通告中写道，计划在2030年终止其大型机和UNIX服务器系统业务。具体来说，该公司会在2030年停止制造和销售其大型机，且其UNIX服务器系统也将止步于2029年底。不过，再加上五年的延长服务支持期，两项业务将分别于2035/2034年正式告别市场。

9.3 UNIX操作系统的安全性及配置

■ 9.3.1 UNIX系统的安全性

从理论上讲，UNIX 操作系统本身并没有什么重大的安全缺陷。多年来，绝大多数在 UNIX 操作系统上发现的安全问题主要存在于个别程序中，并且大部分 UNIX 厂商都声称有能力解决这些问题，可提供安全的 UNIX 操作系统。但是，对任何一种复杂的操作系统而言，时间越久，安全性也就越差。所以，必须时刻警惕安全缺陷，防患于未然。

UNIX安全风险常见的主要问题可能来源于第三方软件或者配置不当。

9.3 UNIX操作系统的安全性及配置

9.3.1 UNIX系统的安全性

1. UNIX安全基础

UNIX系统不仅以内核很简练、高效和丰富的核外程序而著称,而且在防止非授权访问和防止信息泄密方面也很成功。UNIX系统设置了3道安全屏障用于防止非授权访问。首先,必须通过口令认证,确认用户身份合法后才能允许访问系统;但是,对系统内任何资源的访问还必须越过第2道屏障,即必须获得相应访问权限;对系统中重要信息,UNIX系统提供第3道屏障:文件加密。

- 1) 标识和口令
- 2) 文件权限
- 3) 文件加密



9.3 UNIX操作系统的安全

1) 标识和口令

UNIX系统通过注册用户和口令对用户身份进行认证。因此，设置安全的账户并确定其安全性是系统管理的一项重要工作。在UNIX操作系统中，与标识和口令有关信息存储在/etc/passwd文件中。每个用户的信息占一行，并且系统正常工作必需的标准系统标识等同于用户。文件中每行的一般格式为：

LOGNAME:PASSWORD:UID:GID:USERINFO:HOME:SHELL

每行包含若干项，各项之间用冒号（:）分割。第1项是用户名，第2项加密后的口令（DES加密），第3项是用户标识，第4项是用户组标识，第5项是系统管理员设置的用户扩展信息，第6项是用户工作主目录，最后一项是用户登录后将执行的shell全路径（若为空格则缺省为/bin/sh）。

用户和操作系统间的接口

9.3 UNIX操作系统的安全

2) 文件权限

文件系统是整个UNIX系统的“物质基础”。UNIX以文件形式管理计算机上的存储资源，并以文件形式组织各种硬件存储设备如硬盘、CD-ROM、USB盘等。这些硬件设备存放在/dev以及/dev/disk目录下，是设备的特殊文件。文件系统中对硬件存储设备的操作只涉及“逻辑设备”（物理设备的一种抽象，基础是物理设备上的一个个存储区），而非物理设备，可以说一个文件系统就是一个逻辑上的设备，所以，文件的安全是操作系统安全最重要的部分。



9.3 UNIX操作系统的安全

2) 文件权限

UNIX 系统对每个文件属性设置一系列**控制信息**，以此决定用户对文件的访问权限，即谁能存取或执行该文件。在 UNIX 文件系统中，每个文件由**9个二进制位**组成的数据来控制权限信息，它们分别控制文件的**所有者、所有者组和其他成员**对文件的**读、写、执行**的权限，如图 9-1 所示。9个二进制位按每3位为一组，第一组代表所有者，第二组代表所有者组，第三组代表其他成员权限。系统中，可通过 UNIX命令ls-l列出详细文件及控制信息。

9.3 UNIX操作系统的安全

2) 文件权限

Chmod权限修改

(1) 符号模式:

通过u（所有者）、g（所属组）、o（其他用户）、a（所有用户）与+（加）、-（移除）、=（直接设置）组合调整权限。例如：

chmod u+w file.txt: 给文件所有者添加写权限。

chmod a-rwx file.txt: 移除所有用户的读、写、执行权限。

(2) 八进制数字模式

每位数字对应r（4）、w（2）、x（1）的权限值之和：

chmod 755 file.txt: 所有者拥有rwx权限，其他用户为r-x权限。

chmod 640 file.txt: 所有者读写，所属组只读，其他用户无权限。

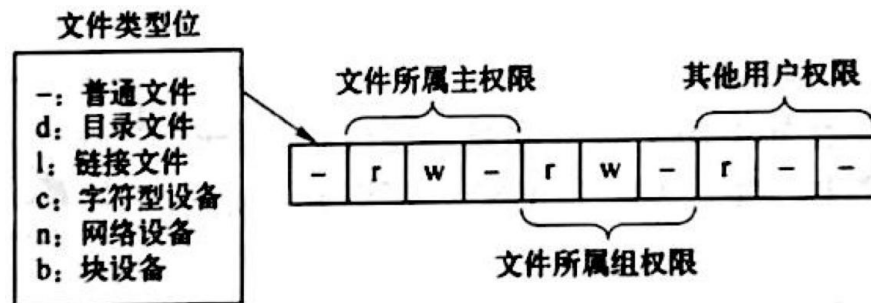


图 9-1 系统权限构成示意图

9.3 UNIX操作系统的安全

3) 文件加密

文件权限的正确设置在一定程度上可以限制非法用户的访问，但是，对于一些高明的入侵者和超级用户仍然不能完全限制读取文件。UNIX系统提供文件加密的方式来增强文件保护，常用的加密算法有crypt（最早的加密工具）、DES（目前最常用的）、IDEA（国际数据加密算法）、RC4、Blowfish（简单高效的DES）、RSA。

crypt命令给用户提供了对文件加密的工具。使用一个key将标准输入的信息编码为不可读的杂乱字符串，送到标准输出设备。再次使用此命令，用同一key作用于加密后的文件，可恢复文件内容。此外，UNIX系统中的一些应用程序也提供文件加/解密功能，如ed、vi和emacs。这类编辑器提供-x选项，具有生成并加密文件的能力：在文件加载时对文件解密，回写时重新进行加密。

9.3 UNIX操作系统的安全

- 但此种加密算法可以通过分析普通英文文本和加密文件中字符出现的频率来破解加密，并且，crypt程序经常被做成特洛伊木马，所以现有的加密机制不能再直接用于文件加密，同时不能用口令作为关键词。最好在加密前用 pack 或 compress 命令对文件进行压缩后再加密。

案例9-2

***利用pack压缩并加密文件.**

```
%pack example.txt
```

```
%cat example.txt.z | crypt >out.file
```

解密时要对文件进行扩张（unpack），

此外，压缩后通常可节约原文件20%到40%的空间。

```
%cat out.file | crypt >example.txt.z
```

```
%unpack example.txt.z
```

9.3 UNIX操作系统的安全

■ 9.3.2 UNIX系统安全配置

■ 1. 设定较高的安全级

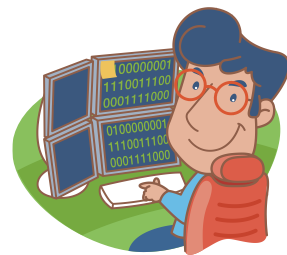
■ UNIX系统共有4种安全级别:①High（高级）;②Improved（改进）;③Traditional（一般）;④Low（低级），安全性由高到低。High级别安全性大于美国国家C2级标准，Improved级别安全性接近于C2级。因此为保证系统具有较高的安全性，最好将UNIX系统级别定为High级。在安装UNIX系统过程中，通过选项可以设置系统级别。同时，级别越高，对参数的要求越高，安全性越好，但对用户的要求也越高，限制也越多。所以，用户需要根据实际情况进行设定。

■ 如果在安装时用户设定的级别过高或较低，可在系统中使用relax命令进行安全级别设定：用#sysadmsh → system → configure → Security → Relax，进行级别设定。

9.3 UNIX操作系统的安全

2. 强用户口令管理

超级用户口令必须加密，而且要经常更换口令，如发现口令泄密需要及时更换。其他用户账户也要求口令加密，也要做到及时更换。用户账户登录及口令的管理信息默认放在/etc/default/passwd和/etc/default/login文件中，系统通过两个文件进行账户及口令的管理。在两个文件中，系统管理员可以设定口令的最大长度、最小长度、口令的最长生存周数、最小生存周数、允许用户连续登录失败的次数、要求口令注册情况（是否要口令注册）等。系统管理员可以对这些参数进行合理化配置，以此完善或增强系统管理。



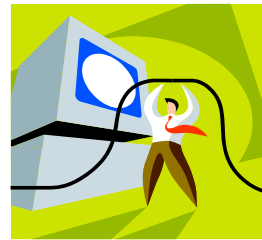
9.3 UNIX操作系统的安全

3. 设立自启动终端

可以理解为应用程序的交互窗口

UNIX是一个多用户系统，一般用户对系统的使用是通过用户注册进入。用户进入系统后便拥有删除、修改操作系统和应用系统的程序或数据的可能性，这样，不利于操作系统或应用于系统程序或数据的安全。通过建立自启动终端的方式，可以避免操作系统或应用系统的程序或数据被破坏。具体方法：

修改/etc/inittab文件，将相应终端号状态由off改为respawn。重新执行
这样，开机后系统自动执行相应的应用程序，终端不需用户登录，用户也无法在login状态下登录。这样，在一定程度上保障了系统的安全。



9.3 UNIX操作系统的安全

4. 建立封闭的用户系统

设立自启动终端的方法固然安全，但不利于系统资源的充分利用，如果用户想在终端上运行其他应用程序，则该方式无法完成。但是，可以建立不同的封闭用户系统，即建立不同的封闭用户账户，自动运行不同的应用系统。当然，封闭用户系统的用户无法用组合键((Ctrl+C)或(Ctrl+Backspace))进入系统的 Shell 状态。

建立封闭帐户的方法是：修改相应帐户的.profile文件.在.profile文件中运行相应的应用程序，在.profile文件的前面再加上中断屏蔽命令，命令格式为trap “1 2 3 15”，在.profile文件末尾再加上一条exit命令。系统运行结束退回login状态。使用trap命令的目的就是防止用户在使用过程中使用ctrl-c或ctrl-backspace命令中止系统程序,退回SHELL状态。

为避免用户修改自己的.profile文件，还需修改.profile的文件权限，权限为640，用户属性为root，用户组为root。通过上述操作便可以建立封闭帐户。

9.3 UNIX操作系统的安全

5. 撤消不用的帐户

在系统使用过程中，根据需要可以建立不同权限的帐户。但是，有些帐户随着情况的变化不再使用，这时，最好将帐户撤消。具体撤消方法是：

sysadmsh → Account → Users → Retire → 输入计划撤消的帐户名称即可。



9.3 UNIX操作系统的安全

6. 限制注册终端功能

对于多用户系统UNIX，可设有多个终端，终端可放在不同的地理位置、不同的部门。为防止其他部门非法使用应用程序，可限定某些应用程序在限定的终端使用。具体的方法：在相应帐户的.profile文件中增加识别终端的语句。如：

```
trap "1 2 3 15"
```

```
case `tty in / dev/ tty21[ a - d ]
```

如终端非/

```
dev/tty21[ a - d ]则无法执行
```

```
clear
```

```
echo“非法终端!”
```

```
exit
```

```
esac
```

```
banking —em —b4461
```

执行应用程序

```
exit
```



9.3 UNIX操作系统的安全

7. 锁定暂不用终端

有些终端暂不使用，可用命令进行锁定，避免其他人在此终端上使用，出现不安全问题。

具体锁定方法是：

sysadmsh → Accounts → Terminal → Lock → 输入要锁定的终端号.如果需要解锁：# sysadmsh → Accounts → Terminal → Unlock → 输入要解锁的终端号。

讨论思考：

- (1) Unix的不安全因素有哪些,体现在什么方面?
- (2) 如何进行对Unix的安全配置,以使Unix操作系统更加安全?



9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

Linux是一套免费使用和自由传播的类Unix操作系统，是一个基于POSIX和Unix的**多用户、多任务、支持多线程和多CPU的操作系统**。它能运行主要的Unix工具软件、应用程序和网络协议。它支持32位和64位硬件。

Linux继承了Unix以网络为核心的设计思想，是一个性能稳定的多用户网络操作系统。Linux以其稳定性和性价比方面的优势受到众多用户的青睐，在政府部门、企业服务器中得到广泛应用，因此也成为黑客攻击的重点目标。

9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

【案例9-6】 由于 Linux 经常用作云服务、虚拟机主机和基于容器的基础设施等，攻击者开始使用日益复杂的漏洞，利用工具和恶意软件攻击 Linux 环境。VMware 日前发布了《揭露基于 Linux 多云环境中的恶意软件》的研究报告，报告数据显示：以勒索软件、加密货币劫持和渗透测试工具破解版为代表的恶意软件，开始越来越多地攻击多云基础设施中的 Linux 系统及应用。

9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

Linux 虽然说是一种类 **UNIX** 的操作系统，但又有不同：**Linux** 不属于某一家厂商，没有厂商宣称对它提供安全保证，因此**用户只能自己解决安全问题**。

作为**开放式操作系统**，**Linux**不可避免地存在一些安全隐患。那么如何解决这些隐患，为应用提供一个安全的操作平台？如果关心**Linux** 的安全性，可以从网络上找到许多现有的程序和工具，这既方便了用户，也方便了攻击者，因为攻击者也能很**容易地找到程序和工具**来潜入 **Linux** 系统，或者盗取 **Linux** 系统上的重要信息。不过，只要用户仔细地设定 **Linux**的各种系统功能，并且加上必要的安全措施，就可以让攻击者无机可乘。

9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

■ 1. 权限提升类漏洞

- 一般来说，利用系统上一些程序的逻辑缺陷或缓冲区溢出的手段，攻击者很容易在本地获得 Linux 服务器上管理员的 root 权限；在一些远程的情况下，攻击者会利用一些以 root 身份执行的有缺陷的系统守护进程来取得 root 权限，或利用有缺陷的服务进程漏洞来取得普通用户权限用以远程登录服务器。如 do_brk() 边界检查不充分漏洞，此漏洞的发现提出了一种新的漏洞防范问题，需要通过扩展用户的内存空间到系统内核的内存空间来提升权限。



9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

■ 2. 拒绝服务类漏洞

- 拒绝服务攻击是目前比较流行的攻击方式，该攻击方式并不会取得服务器权限，而是使服务器崩溃或失去响应。对Linux 的拒绝服务大多数都无须登录即可对系统发起拒绝服务攻击，使系统或相关的应用程序崩溃或失去响应能力，这种方式属于利用系统本身漏洞或其守护进程缺陷及不正确设置进行攻击。另外一种情况，攻击者登录到Linux 系统后，利用这类漏洞，也可以使系统本身或应用程序崩溃。这种漏洞主要由程序对意外情况的处理失误引起，比如写临时文件之前不检查文件是否存在及盲目跟随链接等。

9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

■ 3. Linux内核中的整数溢出漏洞

- Linux Kernel 2.4 NFSv3 XDR 处理器例程远程拒绝服务漏洞在 2003 年7月 29 日公布,影响 Linux Kernel 2.4.21 以下的所有 Linux 内核版本。
- 该漏洞存在于 XDR 处理器中,相关内核源代码文件为 `nfs3xdr.c`。此漏洞是由于一个整型漏洞(正数/负数不匹配)引起的。攻击者可以构造一个特殊的 XDR 头(通过设置变量 `int size` 为负数)发送给 Linux 系统,从而触发此漏洞。当 Linux 系统的 NFSv3 XDR 处理程序收到这个被特殊构造的包时,程序中的检测语句会错误地判断包的大小,在
内核中复制巨大的内存,导致内核数据被破坏,致使Linux系统崩溃。

9.4 Linux操作系统的安全

■ 9.4.1 Linux系统的安全性

■ 4. IP地址欺骗类漏洞

- 由于 TCP/IP 本身的缺陷，导致很多操作系统都存在 TCP/IP 堆栈漏洞，使攻击者进行IP 地址欺骗非常容易实现，Linux 也不例外。虽然 IP 地址欺骗不会对 Linux 服务器本身造成很严重的影响，但是对很多利用 Linux 作为操作系统的防火墙和 IDS 产品来说，这个漏洞却是致命的。



9.4 Linux操作系统的安全

■ 9.4.2 Linux系统安全配置

■ 1. 取消不必要的服务

- 每一个不同的网络服务都有一个服务程序在后台运行，`/etc/inetd` 服务器程序可同时监视多个网络端口，一旦接收到外界连接信息，便执行相应的 TCP或UDP网络服务。
- 1) 首先检查`/etc/inetd.conf`文件，在不要的服务前加上“#”号进行注释。除了 HTTP、SMTP、Telnet 和 FTP 之外，其他服务都应该取消。还有一些报告系统状态的服务，如 `finger`、`efinger`、`systat` 和 `netstat` 等，虽然对系统查错和寻找用户非常有用，但也给攻击者提供了方便。
- 2) `inetd` 利用`/etc/services` 文件查找各项服务所使用的端口。因此，用户必须仔细检查该文件中各端口的设定，以免有安全上的漏洞。在 Linux 中有两种不同的服务形态：一种是仅在有需要时才执行的服务，如 `finger` 服务；另一种是一直在执行的服务。后一类服务在系统启动时就开始执行，因此不能靠修改 `inetd` 停止其服务，而只能通过`/etc/rc.d/rc[n].d/`文件或使用 `Run level editor` 进行修改。

9.4 Linux操作系统的安全

■ 9.4.2 Linux系统安全配置

■ 2. 限制系统的出入

- 在进入 Linux 系统之前，所有用户都需要输入用户账号和口令，只有通过验证后才能进入系统。与其他 UNIX 操作系统一样，Linux 一般将口令加密之后存放在 `/etc/passwd` 文件中，用户可以利用现成的密码破译工具以穷举法猜测出口令。比较安全的方法是设定影子文件 `/etc/shadow`，只允许拥有特殊权限的用户阅读该文件。
只有 root 用户拥有读权限
- 在 Linux 系统中，如果要采用 shadow 文件，必须将所有的公用程序重新编译。比较简便的方法是采用插入式验证模块 (Pluggable Authentication Modules, PAM)，PAM 是一种身份验证机制，可以用来动态地改变身份验证的方法和要求，而不要求重新编译其他公用程序。这是因为 PAM 采用封闭包的方式，将所有与身份验证有关的逻辑全部隐藏在模块内。

9.4 Linux操作系统的安全

■ 9.4.2 Linux系统安全配置

■ 3. 保持最新的系统核心

- 由于 Linux 流通渠道很多，而且经常有更新的程序和系统补丁出现，因此，为了加强系统安全，一定要经常更新系统内核。
- Kernel 是 Linux 操作系统的核心，常驻内存，用于加载操作系统的其他部分，并实现操作系统的基本功能。由于 Kernel 控制主机和网络的各种功能，因此，其安全性对整个系统安全至关重要。早期的 Kernel 版本存在许多众所周知的安全漏洞，而且不太稳定，只有2.0.x以上的版本才比较稳定和安全，新版本的运行效率也有很大改观。在设定Kernel 的功能时，只选择必要的功能，千万不要所有功能全部安装，否则会使Kernel变得很大，既占用系统资源，也会给攻击者留下可乘之机。



9.4 Linux操作系统的安全

■ 9.4.2 Linux系统安全配置

■ 4. 检查登录密码

- 设定登录密码是一项非常重要的安全措施，如果用户的密码设定不合适，就很容易被破译，尤其是拥有超级用户使用权限的用户，如果没有良好的密码，将给系统造成很大的安全漏洞。在多用户系统中，如果强迫每个用户选择不易猜出的密码，将大大提高系统的安全性。但如果 passwd 程序无法强迫每个上机用户使用恰当的密码，要确保密码的安全度就只能依靠密码破解程序。
- 实际上，密码破解程序是黑客工具箱中的一种工具，在使用中将常用的密码或者是英文字典中所有可能作为密码的字符全部用程序加密成密码字，然后将其与Linux 系统的/etc/passwd密码文件或/etc/shadow影子文件相比较，如果发现吻合的密码，就可以获得密码明文。

9.5 操作系统的安全加固和恢复

系统安全加固是指通过一定的技术手段，提高操作系统的主机安全性和抗攻击能力，通过**打补丁、修改安全配置、增加安全机制等方法**，合理进行安全性加强，满足安全配置、安全运行、安全接入、数据安全的要求。**常见方法**：**密码系统安全增强、访问控制策略和工具、远程维护的安全性、文件系统完整性审计、增强系统日志分析。**

系统安全加固在一定程度上可以避免系统被攻击或控制、用户数据被篡改、隐私泄露、网站拒绝服务等，但当系统或数据已遭到破坏的情况下，还需要进行**系统恢复**工作。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

安全加固是指对操作系统进行安全设置并消除其漏洞和隐患，提升操作系统的安全等级。一般会参照特定系统加固配置标准或行业规范，根据系统的安全等级划分和具体要求，对相应系统实施不同策略的安全加固，从而保障信息系统的安全。

操作系统的加固主要是通过人工的方式进行，或借助特定的安全加固工具完成。加操作之前应该做好充分的风险规避措施，加固活动会有跟踪记录，以确保系统的可用性。

以下以 Windows 操作系统和 Linux 操作系统为例，介绍系统安全加固的方法。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ 1. Windows操作系统安全加固方法

- (1) 账户管理：“控制面板” → “管理工具” → “本地安全策略”选项。
 - 1) 账户：主要涉及“默认账户安全”“不显示上次登录”等安全配置。配置方法：在“本地策略”的“安全”选项中双击“交互式登录：不显示最后的用户名”，在弹出对话框中选择“已启用”并单击“确定”。
 - 2) 口令：最短密码长度要求至少 8 个字符，至少包含英文大写字母、小写字母、数字、特殊符号这4种类别中的两种。配置方法：在“账户策略”下的“密码策略”中，确认“密码必须符合复杂性要求”策略已启用。
 - 3) 密码最长留存期：对于采用静态口令认证技术的设备，在“账户策略”下的“密码策略”中，配置“密码最长使用期限”不大于 90 天。
 - 4) 帐户锁定策略：对于采用静态口令认证技术的设备，在“账户策略”下的“账户锁定策略”中，配置“账户锁定阈值”不大于 10 次。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

- (2) 认证授权：“控制面板” → “管理工具” → “本地安全策略”选项，在“本地策略”的“用户权限分配”中进行配置。
 - 1) 远程关机：配置方法：配置“从远端系统强制关机”权限只分配给 Administrators 组。
 - 2) 本地关机：配置“关闭系统”权限只分配给 Administrators 组。
 - 3) 用户权限指派：配置“取得文件或其他对象的所有权”只分配给 Administrators 组。
 - 4) 授权帐户登录：配置“允许本地登录”权限给指定授权用户。
 - 5) 授权帐户从网络访问：在本地安全设置中，只允许授权账户从网络访问（包括网络共享等，但不包括终端服务）此计算机。配置方法：配置“从网络访问此计算机”权限给指定授权用户。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

- (3) 日志配置操作：“控制面板”→“管理工具”→“本地安全略”选项，在“本地策略”的“审核策略”中进行配置。
 - 1) 日志配置：审核登录。记录内容包括用户记录使用的账户、登录是否成功、登录时间以及远程登录时用户使用的IP地址。配置方法：设置“审核登录事件”。
 - 2) 审核策略更改：成功和失败操作都需要审核。
 - 3) 审核对象访问：成功和失败操作都需审核。
 - 4) 审核事件目录服务访问：仅需审核失败操作。
 - 5) 审核特权使用：成功和失败操作都需审核。
 - 6) 审核系统事件：成功和失败操作都需审核。
 - 7) 审核帐户管理：成功和失败操作都需审核。
 - 8) 审核过程追踪：仅需审核失败操作。
 - 9) 日志文件大小：设置应用日志文件大小至少为20480KB，并设置当达到最大的日志尺寸时，按需要轮询记录日志。配置方法：“控制面板”→“管理工具”→“事件查看器”选项，配置“Windows 日志”属性中的日志大小，以及设置当达到最大的日志尺寸时的相应策略。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ (4) IP协议安全配置

- **IP协议安全：启用 SYN 攻击保护。**指定触发 SYN Flood 攻击(泛洪攻击)保护所必须超过的 TCP 连接请求数阈值为 5；指定处于 SYN RCVD 状态的 TCP 连接数的阈值为500；指定处于至少已发送一次重传的 SYN RCVD 状态中的 TCP 连接数的阈值为 400。配置方法：打开**注册表编辑器**，根据推荐值修改注册表键值。

■ (5) 文件权限

- **共享文件夹及访问权限：**默认共享关闭，注册表编辑器。
- **共享文件夹授权访问：**“控制面板” → “管理工具” → “计算机管理” → “共享文件夹”。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ (6) 服务安全：“计算机管理” → “服务和应用程序” → “服务”。

■ 禁用TCP/IP上的NetBIOS

■ 禁用不必要的服务

服务名称	建议
DHCP Client	如果不使用动态IP地址，就禁用该服务
Background Intelligent Transfer Service	如果不启用自动更新，就禁用该服务
Computer Browser	禁用
Diagnostic Policy Service	手动
IP Helper	禁用。该服务用于转换IPv6 to IPv4
Print Spooler	如果不需要打印，就禁用该服务
Remote Registry	禁用。Remote Registry主要用于远程管理注册表
Server	如果不使用文件共享，就禁用该服务。禁用本服务将关闭默认共享，如ipc\$、admin\$和c\$等
TCP/IP NetBIOS Helper	禁用
Windows Remote Management (WS-Management)	禁用
Windows Font Cache Service	禁用
WinHTTP Web Proxy Auto-Discovery Service	禁用
Windows Error Reporting Service	禁用

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ (7) 安全选项

■ 启用安全选项

■ 禁用未登录前关机

安全选项	配置内容
交互式登录: 试图登录的用户的消息标题	注意
交互式登录: 试图登录的用户的消息文本	内部系统只能因业务需要而使用, 经由管理层授权。 管理层将随时监测此系统的使用。
Microsoft 网络服务器: 对通信进行数字签名(如果客户端允许)	启用
Microsoft 网络服务器: 对通信进行数字签名(始终)	启用
Microsoft 网络客户端: 对通信进行数字签名(如果服务器允许)	启用
Microsoft 网络客户端: 对通信进行数字签名(始终)	启用
网络安全: 基于 NTLM SSP 的(包括安全 RPC)服务器的最小会话安全	要求 NTLMv2 会话安全 要求 128 位加密
网络安全: 基于 NTLM SSP 的(包括安全 RPC)客户端的最小会话安全	要求 NTLMv2 会话安全 要求 128 位加密
网络安全: LAN 管理器身份验证级别	仅发送 NTLMv2 响应\拒绝 LM & NTLM
网络访问: 不允许 SAM 帐户的匿名枚举	启用 (默认已启用)
网络访问: 不允许 SAM 帐户和共享的匿名枚举	启用
网络访问: 可匿名访问的共享	清空 (默认为空)
网络访问: 可匿名访问的命名管道	清空 (默认为空)
网络访问: 可远程访问的注册表路径	清空, 不允许远程访问注册表
网络访问: 可远程访问的注册表路径和子路径	清空, 不允许远程访问注册表

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ (8) 其他安全配置

- 1) 防病毒管理。Windows系统需要安装防病毒软件。
- 2) 设置屏幕保护密码和开启时间。设置从屏幕保护恢复时需要输入密码，并将屏幕保护自动开启时间设定为五分钟。
- 3) 远程登录空闲断开时间。对于远程登录的帐户，设置不活动超过时间15分钟自动断开连接。
- 4) 操作系统补丁管理。安装最新的操作系统Hotfix补丁。安装补丁时，应先对服务器系统进行兼容性测试。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ 2. Linux操作系统安全加固方法

■ (1) 账号和口令

■ 1) 禁用或删除无用账号

- 使用命令 `userdel <用户名>` 删除不必要的账号。
- 使用命令 `passwd -l<用户名>` 锁定不必要的账号。
- 使用命令 `passwd -u<用户名>` 解锁必要的账号。

■ 2) 检查特殊账号

- 查看空口令和 `root` 权限账号，确认是否存在异常账号。
 - 使用命令 `awk -F:($2-'"') /etc/shadow` 查看空口令账号
 - 使用命令 `awk -F:($3-0)' /etc/passwd` 查看 UID 为零的账号。
- 加固空口令账号。
 - 使用命令 `passwd<用户名>` 为空口令账号设定密码。
 - 确认 UID 为零的账号只有 `root` 账号。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ 2. Linux操作系统安全加固方法

■ 3) 添加口令策略

- 使用命令 `vi /etc/login.defs` 修改配置文件: `PASS_MAX_DAYS 90`、`PASS_MIN_DAYS 0`、`PASS_WARN_AGE 7`、`PASS_MIN_LEN 8`。
- 使用 `chage` 命令修改用户设置: `chage -m 0 -M 30 -E 2021-01-01 -W 7 <用户名>`。
- 设置连续输错3次密码, 账号锁定 5min。使用命令 `vi /etc/pam.d/common-auth` 修改配置文件, `auth required pam_tally.so onerr-fail deny=3 unlock_time=300`

■ 4) 限制用户su

- 使用命令 `vi /etc/pam.d/su` 修改配置文件, 例如, `auth required pam_wheel.so group=test`。

■ 5) 禁止root用户直接登录

- 使用命令 `vi/etc/ssh/sshd_config` 修改配置文件, 将 `PermitRootLogin` 的值改成 `no`, 并保存, 然后使用命令 `service sshd restart` 重启服务。

9.5 系统的加固和恢复

9.5.1 系统加固的常用方法

2. Linux操作系统安全加固方法

(2) 服务

1) 关闭不必要的服务

- 使用命令 `systemctl disable <服务名>` 设置服务在开机时不自动启动

2) SSH服务安全：配置密钥登录、设置密码错误次数等。

(3) 文件系统

1) 设置umask值。使用命令 `vi /etc/profile` 修改配置文件，添加行 `umask 027`，即新创建的文件属主拥有读写执行权限，同组用户拥有读和执行权限，其他用户无权限。

2) 设置登录超时。使用命令 `vi /etc/profile` 修改配置文件，设置为 `TMOUT=180`，即超时时间为 3min。

9.5 系统的加固和恢复

■ 9.5.1 系统加固的常用方法

■ (4) 日志

■ 1) syslog日志。Linux系统默认启用以下类型日志：

- 系统日志（默认） /var/log/messages
- cron日志（默认） /var/log/cron
- 安全日志（默认） /var/log/secure

■ 2) 记录所有用户的登录和操作日志。

- 通过脚本代码实现记录所有用户的登录操作日志，防止出现安全事件后无据可查。

9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

1. 软件恢复

- 软件恢复可分为**系统恢复与文件恢复**。
- 系统恢复是指在系统无法正常运作的情况下，通过调用已经备份好的系统资料或系统数据、使用恢复工具等，使系统按照备份时候的部分或全部正常启动运行的数值特征来进行运作。
- **常见的文件系统故障**有误删除、误格式化、误GHOST、分区出错等，绝大部分各种操作系统都可以进行恢复。



数据恢复



9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

【案例 9-10】 主引导记录损坏后的恢复。IBM 40GB 的台式机硬盘在运行中突然断电，重启主机后无法启动进入系统。通过使用 WinHex 工具打开硬盘，发现其 MBR 扇区已经被破坏。由于 MBR 扇区不会因操作系统而不同，具有公共引导特性，可以采用复制引导代码将其恢复。其主引导扇区位于整个硬盘的 0 柱面 0 磁道 1 扇区，共占用 63 个扇区，实际使用了 1 个扇区。在此扇区的主引导记录中，MBR 又可分为 3 部分：引导代码、分区表和 55AA（结束标志）。

9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

2. 硬件修复

硬件修复方式可分为硬件替代、固件修复、盘片读取三种。

(1) 硬件替代

- ◆ 硬件替代是用同型号的好硬件替代坏硬件达到恢复数据之目的，简称“替代法”。如果BIOS不能找到硬盘，则基本可以判断是硬件损坏，须使用硬件替代。

(2) 固件修复

- ◆ 固件是硬盘厂家写在硬盘中的初始化程序，一般工具是访问不了的。固件修复，就是用硬盘专用修复工具，修复硬盘固件，从而恢复硬盘数据。

(3) 盘片读取

- ◆ 盘片读取是较为高级的技术，就是在100 级的超净工作间（ ≤ 100 个/立方英尺（ $\approx 3,530$ 个/立方米））内对硬盘进行开盘，取出盘片，然后用专门的数据恢复设备对其扫描，读出盘片上的数据。

9.5 系统的加固和恢复

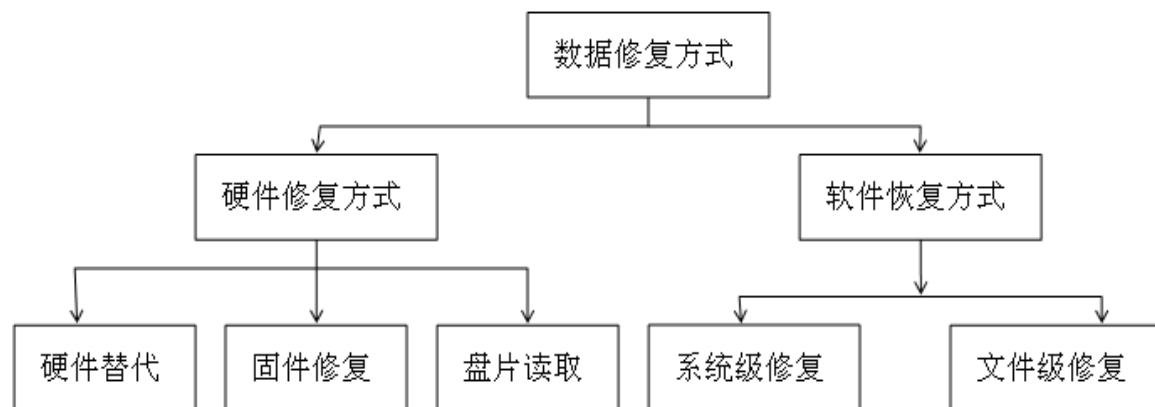
9.5.2 系统恢复常用方法及过程

3. 数据修复

数据修复是指通过技术手段，将受到病毒攻击、人为损坏或硬件损坏等遭到破坏的数据进行抢救和恢复的一门技术。

数据被破坏的主要原因主要是入侵者的攻击、系统故障、误操作、自然灾害等造成的。通常，数据恢复就是从存储介质、备份和归档数据中将丢失数据恢复。

数据修复技术、方法和工具：常用有**数据备份**、**数据恢复**和**数据分析**等。**修复方式**可分为**软件恢复方式**与**硬件修复方式**。



9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

3. 数据修复

- **数据修复的原理。**从**技术层面**上，各种数据记录**载体**（**硬盘、软盘**）中的数据**删除**时只是**设定**一个**标记**（识别码），而并没有从载体中**绝对删除**。使用过程中，**遇到**标记时，系统对这些数据**不做**读取处理，并在**写入**其他数据的时候将其当作空白区域。所以，这些被删除的数据在没有被其他数据写入前，依然**完好地**保留在磁盘中。不过，读取这些数据需要**专门**的软件。如Easyrecovary、WinHex等。当其他数据**写入**时，原来数据就被**覆盖**（全部或部分），此时数据只能**恢复部分**。

9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

4. 系统恢复的过程

- 进行系统恢复工作，重新获取系统控制权，需要按照如下步骤及过程展开。

(1) 断开网络

(2) 备份

(3) 入侵分析

- ◆ 1) 系统软件和配置文件审查。
- ◆ 2) 检测被修改的数据
- ◆ 3) 查看入侵者留下的工具和数据
- ◆ 4) 审查系统日志文件
- ◆ 5) 检查网络上的其他系统
- ◆ 6) 检查涉及的或者受到威胁的远程站点



9.5 系统的加固和恢复

9.5.2 系统恢复常用方法及过程

4. 系统恢复的过程

■ 入侵者通常会在系统中安装一些工具，以便继续监视被侵入的系统。通常**需要注意查看以下文件**：

- ◆①网络嗅探器是监视和记录网络行动的工具程序。
- ◆②特洛伊木马程序能够在表面上执行某种功能，而实际上执行另外的功能。
- ◆③后门程序。
- ◆④安全缺陷攻击程序。

讨论思考：

- 1) 为什么要进行操作系统安全加固？
- 2) 什么是数据修复？数据修复的方式有哪些？
- 3) 系统恢复遵循什么步骤？
- 4) 如何分析被入侵的系统？



9.6 本章小结

本章小结

本章介绍操作系统安全的相关知识。其中，**Windows**操作系统的系统安全性以及安全配置是重点之一。简要介绍了**Unix**操作系统的安全知识。介绍了源代码公开的**Linux**操作系统的安全和安全配置相关内容。介绍了操作系统安全加固方法。被入侵后的恢复是一种减少损失的很好方式，可以分为系统恢复与信息恢复，本章重点对系统恢复的过程进行介绍。

9.7 Windows Server 2022安全配置实验

Windows Server 2022是微软的**服务器操作系统**，继承了Windows Server 2019的功能和特点，尽管Windows Server 2022系统的安全性能要比其他系统的安全性能高出许多，但为了增强系统的安全，必须要进行安全的配置，并且在系统遭到破坏时能恢复原有系统和数据。

9.7.1 实验目的

- (1) 熟悉Windows Sever 2022操作系统的安全配置过程及方法；
- (2) 掌握Windows Sever 2022操作系统的恢复要点及方法。



9.7 Windows Server 2019安全配置实验

9.7.2 实验要求

1. 实验设备

本实验以Windows Sever 2022操作系统作为实验对象，所以，需要一台主机并且安装有Windows Sever 2022操作系统。Microsoft在其网站上公布使用Windows Server 2022的设备需求。

实验设备基本配置表

硬 件	需 求
处理器	建议： 2 GHz 或以上
内存	最低： 1 GB RAM，建议： 2 GB RAM 或以上
可用磁盘空间	最低： 32 GB，建议： 40 GB 或以上
光驱	DVD-ROM 光驱
显示器	支持 Super VGA (1024× 768) 或更高解析度的萤幕
其他	键盘及鼠标或兼容的指向装置 (pointing device)

2. 注意事项

- 1) 预习准备。
- 2) 注重内容的理解。
- 3) 实验学时。本实验大约需要2个学时（90-120分钟）完成。

9.7 Windows Server 2019安全配置实验

9.7.3 实验内容及步骤

1.本地用户管理和组：某公司秘书授权可以登录领导的主机，定期为领导备份文件，并执行网络配置方面等有关管理工作，因此，在领导的主机中要新建一个用户组，满足秘书的应用需求。

操作步骤：新建账户“secretary”和用户组“日常工作”，“日常工作”组具有“Network Configuration Operators”的权限，并 secretary 添加到“日常工作”组中。

(1) 新建账户：“开始”→“管理工具”→“计算机管理”，弹出窗口，展开“本地用户和组”，右键单击“用户”，新建“secretary”账户。

(2) 管理账户：右键单击账户，可以设置密码、删除账号或重命名；右键单击账户，选择“属性”，在“隶属于”选项卡中将 secretary 帐户添加到 Backup Operations 组和 Net Configuration Operators 组中，即为 secretary 帐户授予 Backup Operations 组和 Net Configuration Operators 组的权限。

(3) 新建本地组：右键单击“组”，窗口，填写组名和描述信息，并选择“添加”，将 secretary 添加到日常工作组中，这样，日常工作组也具有 Backup Operations 组和 Net Configuration Operators 组的权限。

9.7 Windows Server 2019安全配置实验

2.本地安全策略:公司管理层计算机安全策略要求: 启用密码复杂性策略, 将密码最小长度设置为8个字符, 设置密码使用期限为30天, 当用户多次输入错误数据超过3次账户将被锁定, 锁定时间为5分钟; 启用审核登录成功和失败策略, 登录失败后, 通过事件查看器查看Windows日志; 启用审核对象访问策略, 用户对文件访问后, 通过事件查看器查看Windows日志。

操作步骤: 在本地安全策略中分别设置密码策略、账户锁定策略、审核登录时间策略和审核对象访问策略。

(1) **密码策略设置:** “开始” → “管理工具” → “本地安全策略” → “账户策略” → “密码策略”, 启动密码复杂性策略; 设置“密码长度最小值”为“8”个字符; 密码最长使用期限为“30”天。

(2) **账户锁定策略设置:** “开始” → “管理工具” → “本地安全策略” → “账户策略” → “账户锁定策略”, 设置账户锁定时间为“5”分钟; 账户锁定阈值为“3”次。

(3) **审核策略设置:** “开始” → “管理工具” → “本地安全策略” → “本地策略” → “审核策略”, 审核登录策略设置为“失败”; 审核对象策略设置为“失败”。

9.7 Windows Server 2019安全配置实验

3. NTFS权限：经理要下发一个通知，存于“通知”文件夹中，经理对该文件夹及文件可以完全控制，秘书只有修改文稿的权限，其他人员只有浏览的权限。

操作步骤：首先要取消“通知”文件夹的父项继承的权限，之后分配Administrators组（经理）完全控制的权限、日常工作组（秘书）除了删除权限以外各权限和Users组（其他人员）只读权限。

(1) 取消文件夹的父项继承的权限：右键单击“通知”文件夹，选择“属性”命令→“安全”标签→“高级”→“更改权限”，打开高级安全设置窗口，添加日常工作组和Users组到列表中，分别选择两组，取消“包括可从该对象的父项继承的权限”选项。删除继承权后，任何用户对该文件夹都无访问权限，只有该对象的所有者可分配权限。

(2) 经理权限：右键单击“通知”文件夹，选择“属性”命令→“安全”标签→“高级”→“更改权限”→“高级”→“添加”，添加经理的Administrator账户，点击“确定”后打开“通知的权限项目”窗口，选择“允许”→“完全控制”。

(3) 秘书权限：在“通知的高级安全设置”窗口中继续添加日常工作组，点击“确定”后打开“通知的权限项目”窗口，选择“允许”→“创建文件/写入数据”。

(4) 其他用户权限：在“通知的高级安全设置”窗口中继续添加Users组，点击“确定”后打开“通知的权限项目”窗口，选择“允许”→“列出文件夹/读取数据”。

9.7 Windows Server 2019安全配置实验

4.数据备份和还原：公司为了考核每个员工的工作执行情况，秘书要对每个员工每天任务完成情况填写“工作日志”，并定期汇总，为了防止大量数据丢失，公司要求每周五下班前进行数据备份，即使系统出现安全问题，也可以进行数据恢复。

操作步骤：首先要在系统中安装Backup功能组件,所有人员工作日志按照每天一文件夹存放,这样可以每周五对该周日志进行一次备份。

- 1) **安装备份功能组件：**“开始”下的“服务器管理器”中“添加角色和功能”，选择“Windows Server 备份”安装系统备份功能。
- 2) **一次性备份：**“开始”下的“Windows附件”中“Windows Server 备份”，该界面的右侧可以选择“一次性备份”，当向导进行到“选择备份配置”时，选择“自定义”，之后选择“系统磁盘”进行备份。
- 3) **备份计划：**“开始”下的“Windows附件”中“Windows Server 备份”，该界面的右侧可以选择“备份计划”，根据“备份计划向导”完成备份计划设置。

9.5 Windows Server 2019安全配置实验

5.组策略应用：实现对于多用户应用域中主机登录，其驱动器F：自动连接到\\PC\tools文件夹上。

操作步骤：前提是多用户应用域统一管理，首先要建立一个组策略对象，名为“共享资源”，之后链接组策略对象。

(1) 建立组策略对象：“开始”~~控制面板~~“管理工具”→“组策略管理”，选择要实现驱动器映射的主机所在的域，并右键单击“组策略对象”，选择“新建”命令，新建一个名字为“共享资源”的GPO。右键单击“共享资源”，选择“编辑”命令，“组策略管理编辑器”→“用户配置”→“首选项”→“Windows设置”，右键单击“驱动映射”，选择“新建”→“映射驱动器”，在“常规”选项卡中“操作”项下选择“创建”，在“位置”栏中输入“\\PC\tools”，在“驱动器号”区域中选择“使用”“Z”，完成操作。

(2) 链接组策略对象：在“组策略管理”控制台中，右键单击对应的主机，选择“链接现有GPO”命令，在窗口中“查找此域”下拉列表中选择对应的域名，在“组策略对象”列表框只选择“共享资源”，完成驱动器映射域管理。

“十三五”国家重点出版规划
项目,上海市高校优秀教材奖

上海市高校精品课程特色教材
上海市高校优质在线课程教材

诚挚谢意!

网络安全技术及应用

国家智慧教育平台

国家智慧教育平台-上海精品/优质在线课程



网络安全技术

(第5版,慕课微课版立体化)

